



Seguridad

- IIC2173 - Arquitectura de sistemas de software
- Departamento de Ciencia de la Computación
- Escuela de Ingeniería – PUC
- Nicolás Acosta – Gerardo Crot

ISO25010: Donde ubicamos seguridad

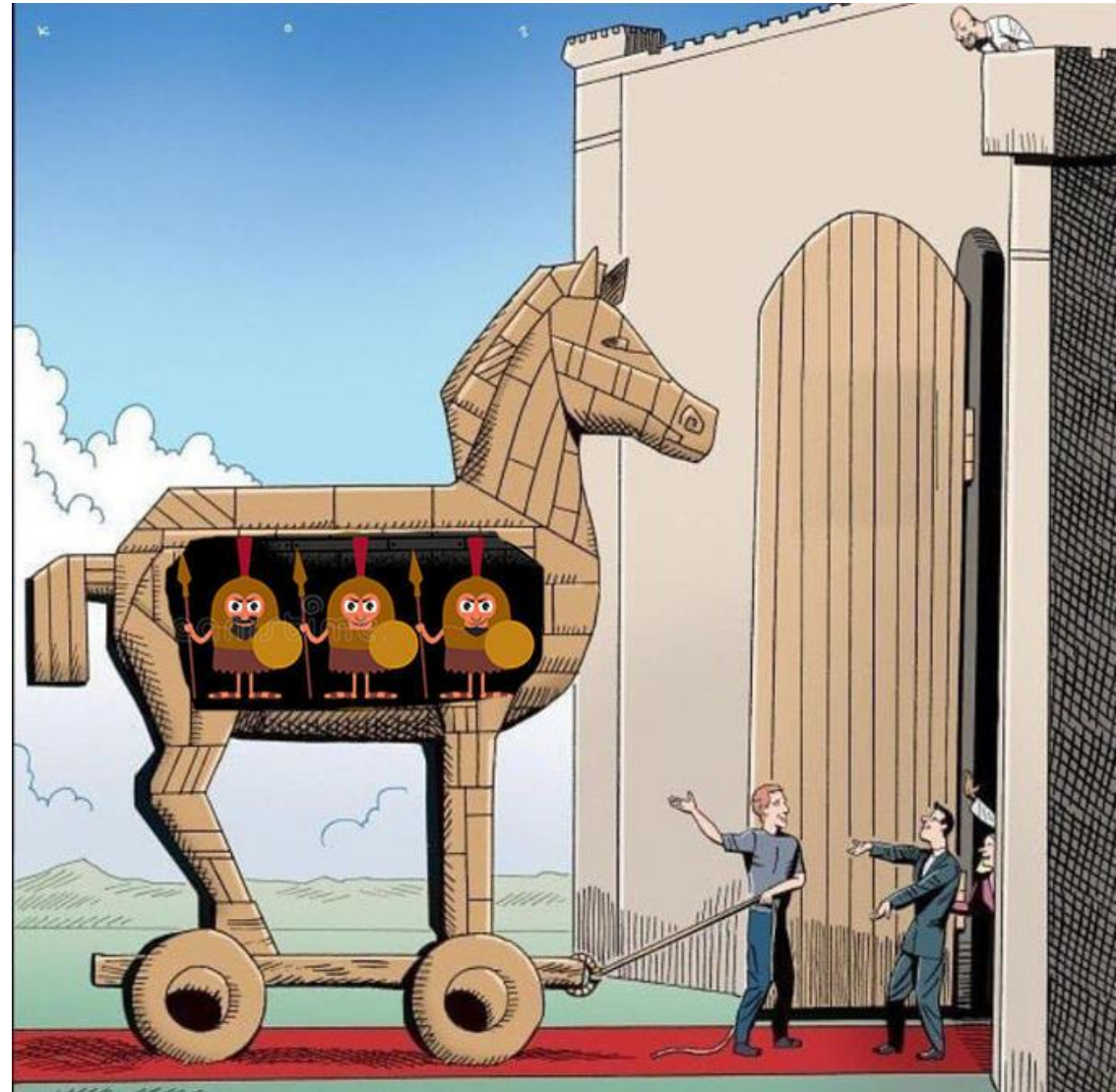


Sobre la información

A single consumer's stolen credit information card sells for around \$5 to \$150 dollars depending on the amount of supplementary data included. A name, address and CVV number all add to the value of the card, but not by much

Ejemplos históricos: Caballo de Troya (~1190 AC)

- En un asedio histórico, se regaló un caballo con soldados ocultos en el interior.
- El asalto fue un éxito y los soldados abrieron las puertas.
- **Lección:** ¡Valida el input! - ¡Nunca sabes qué podría estar escondiendo el caballo!



Ejemplos históricos: Château Gaillard, Normandía Francia (~1200 DC)

- El castillo fue asediado por años sin mayor éxito hasta que se dieron cuenta que habían “canales” para sacar los desechos
- **Lección:** Un punto débil es todo lo que se necesita para arruinar la seguridad de un sistema (eslabón más débil)



Ejemplos históricos: Línea Maginot y WW2 (~1940 DC)

- Se creó una muralla gigantesca y búnkeres para prevenir el avance de los tanques.
- Los alemanes habían creado tanques más rápidos que podían cubrir mayores distancias y pasar un bosque que se creía infranqueable
- **Lección:** Los atacantes van a seguir evolucionando. Hay que mantener actualizadas las defensas para prevenir accidentes



Ejemplos históricos: Proyecto Venona (~1946 DC)

- Durante la guerra fría, desconfiando de posible espionaje los estadounidenses monitoreaban los mensajes entre los soviéticos. Hasta que estos "sobre-publicaron" su clave de encriptación.
- Lección: Tus métodos de encriptación son tan buenos como su implementación

LFHNY ZAHSE JRNKK SYMFU KOZAT
VRETH JPCSU RUSYQ JXKNH ELDEL
PODYF JJLVJ XFSKL HPLGA ZXYZY
TSUIO XBNKI NBSND HPNPI OZVOZ
EYJWF OBXKR PNTVY YTKSK ATOPW
NHCKJ FPHSV SHZZN QQZYN CYSDE
YIIUJ TWRZ QHRDE YOVRJ HOCGY
HALOK NHIIM CAIDV RDTKH ZDZMP
OINDS CMOFK XSBVJ CAYSO IABMU
KLSZX OZJIM DBRCY SHUVZ LFRXT
TATI WIFM IHNSF RUVCY UITRN
NQONG ZUBZB EPVJX NCZZY FBTEX
VEIOE HDVTN GSSNG LRZEG UKUGK
POFRI QCFAA NLTKE DANDQ GAIHU
HEINQ LOTWP MVBHX MNUUK ACPKA
AYGFS ZNFOD SYNXX IYIPD RJCEK
PROPO JFBIQ NYLIX GBTNC QQXXH
FSGNA UDTLB UNKAN HARMG TZVXH
UGBOA JXMFY HTUNH NCTXM OFLSY

A	ABCDEFGHIJKLMNOPQRSTUVWXYZ
B	ZYXWVUTSRQPONMLKJIHGFEDCBA
C	ABCDEFGHIJKLMNOPQRSTUVWXYZ
D	ZYXWVUTSRQPONMLKJIHGFEDCBA
E	ABCDEFGHIJKLMNOPQRSTUVWXYZ
F	ZYXWVUTSRQPONMLKJIHGFEDCBA
G	ABCDEFGHIJKLMNOPQRSTUVWXYZ
H	ZYXWVUTSRQPONMLKJIHGFEDCBA
I	ABCDEFGHIJKLMNOPQRSTUVWXYZ
J	ZYXWVUTSRQPONMLKJIHGFEDCBA
K	ABCDEFGHIJKLMNOPQRSTUVWXYZ
L	ZYXWVUTSRQPONMLKJIHGFEDCBA
M	ABCDEFGHIJKLMNOPQRSTUVWXYZ
N	ZYXWVUTSRQPONMLKJIHGFEDCBA
O	ABCDEFGHIJKLMNOPQRSTUVWXYZ
P	ZYXWVUTSRQPONMLKJIHGFEDCBA
Q	ABCDEFGHIJKLMNOPQRSTUVWXYZ
R	ZYXWVUTSRQPONMLKJIHGFEDCBA
S	ABCDEFGHIJKLMNOPQRSTUVWXYZ
T	ZYXWVUTSRQPONMLKJIHGFEDCBA
U	ABCDEFGHIJKLMNOPQRSTUVWXYZ
V	ZYXWVUTSRQPONMLKJIHGFEDCBA
W	ABCDEFGHIJKLMNOPQRSTUVWXYZ
X	ZYXWVUTSRQPONMLKJIHGFEDCBA
Y	ABCDEFGHIJKLMNOPQRSTUVWXYZ
Z	ZYXWVUTSRQPONMLKJIHGFEDCBA

Hawaii Cryptologic Center (2013)

- Edward Snowden va como “administrative contractor” o “infrastructure analysts” y accede a muchos datos que van mucho más allá de sus responsabilidades. (PRISM)
- **Lección:** Sin importar cuando confías en los usuarios del sistema, **limita el acceso a la información**. La regla de oro es: “ni más ni menos de la información necesaria para hacer su trabajo”



Sobre la seguridad

“La habilidad de un sistema de **proteger datos e información** de acceso no autorizado, proveyendo acceso a usuarios y sistemas que si están autorizados”

(Bass,Kazman)

“Capacidad del software para **proteger información y datos** tal que los usuarios o sistemas tengan el grado de acceso a datos adecuado a sus tipos y niveles de autorización”

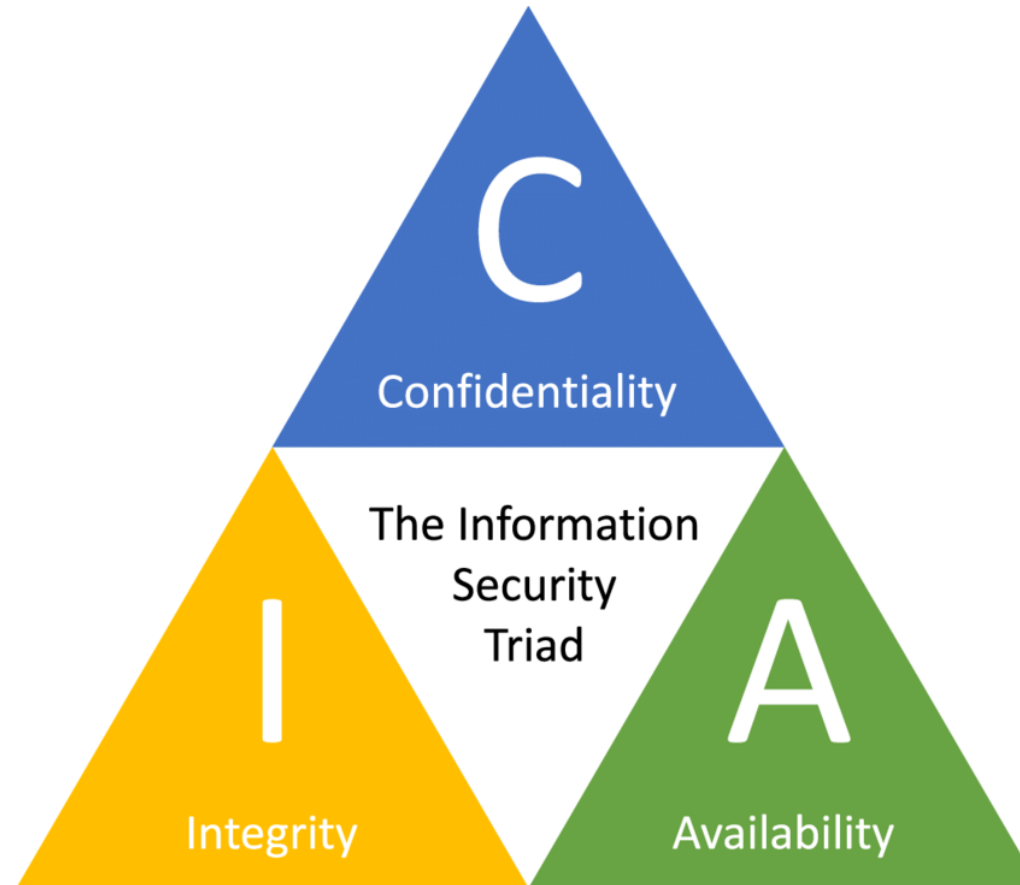
(FOSA)



Meta

- Proteger recursos contra amenazas
 - Servidores
 - Aplicaciones
 - Páginas web
 - Datos
- Ejemplos
 - Corrupción
 - Acceso no autorizado
 - Denegación de acceso autorizado
 - Software malicioso

Acercamiento esencial: CIA





CIA: Bass Kazman

- Esencial (3 pilares)
 - Confidentiality: Proteger del acceso no autorizado
 - Integridad: Datos protegidos de manipulación no autorizada
 - Availability: Disponibilidad para uso legítimo
- Soporte
 - Autenticación: Verifica las identidades de las partes
 - No repudiación: No se puede negar la cadena de movimiento de información
 - Autorización: Proporciona privilegios para realizar una tarea

Sobre Availability (Bass, Kazman)

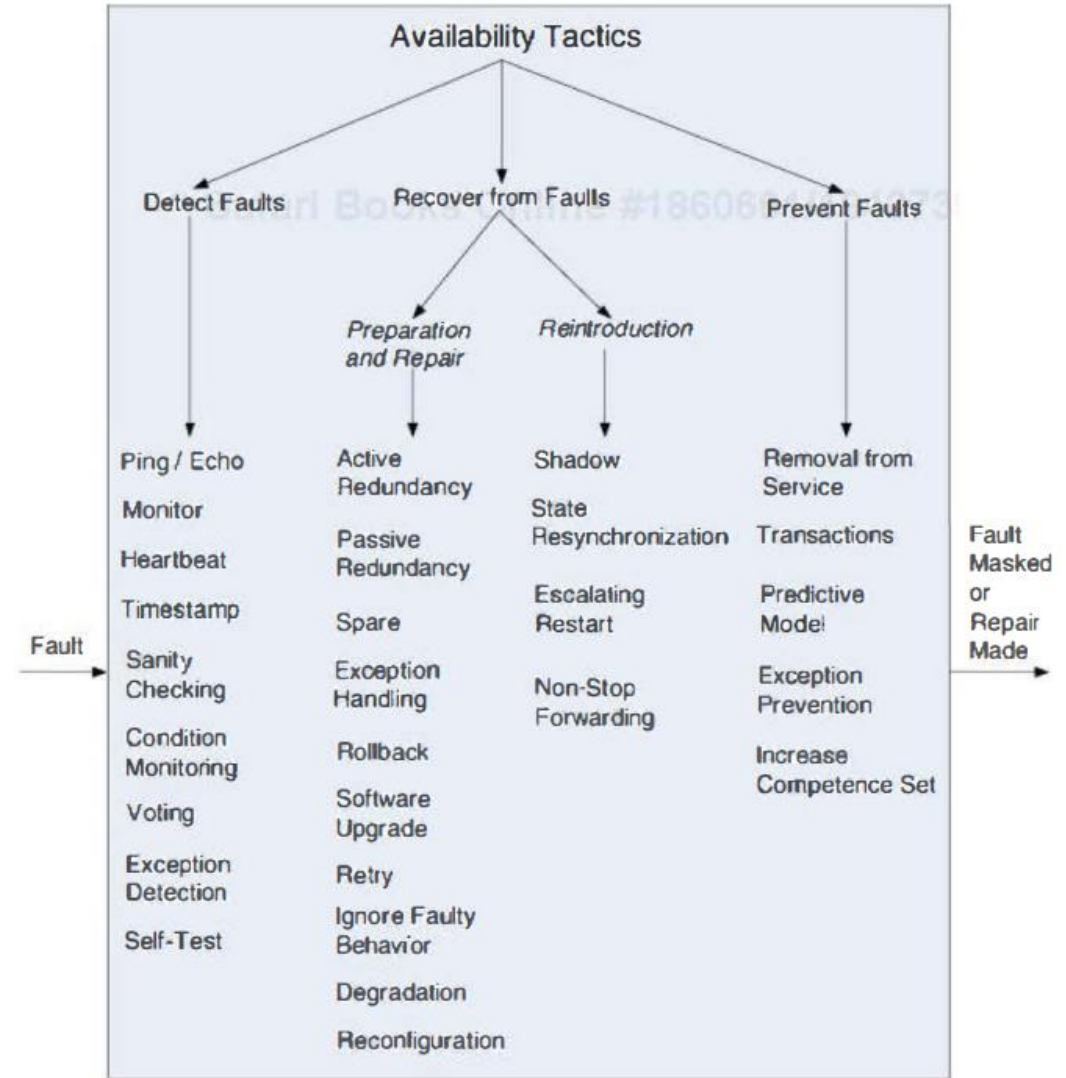
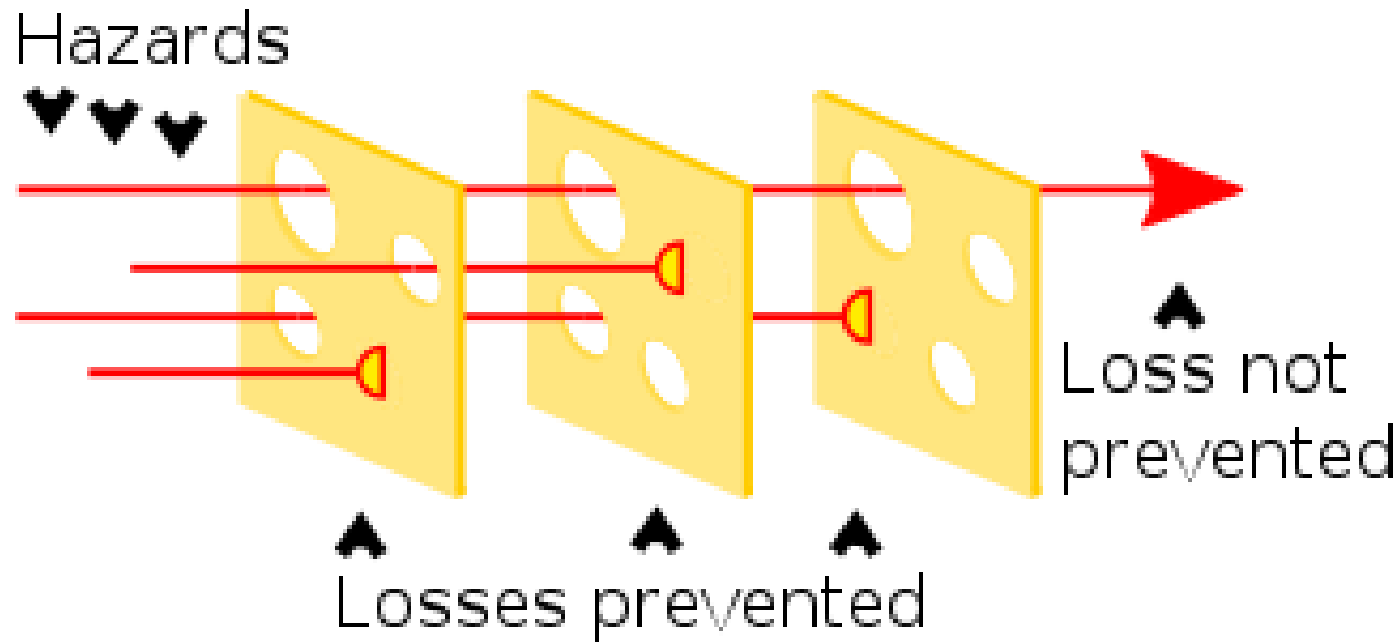


Figure 5.5. Availability tactics

Principios básicos



- Mínimo privilegio: Aplicado exhaustivamente (e.g. IAM)
- Defensa en profundidad: Múltiples capas de seguridad
- Falla segura: Si el sistema falla, debe poder retornar a un estado seguro
- Separación de responsabilidades: Prevenir SPOFs

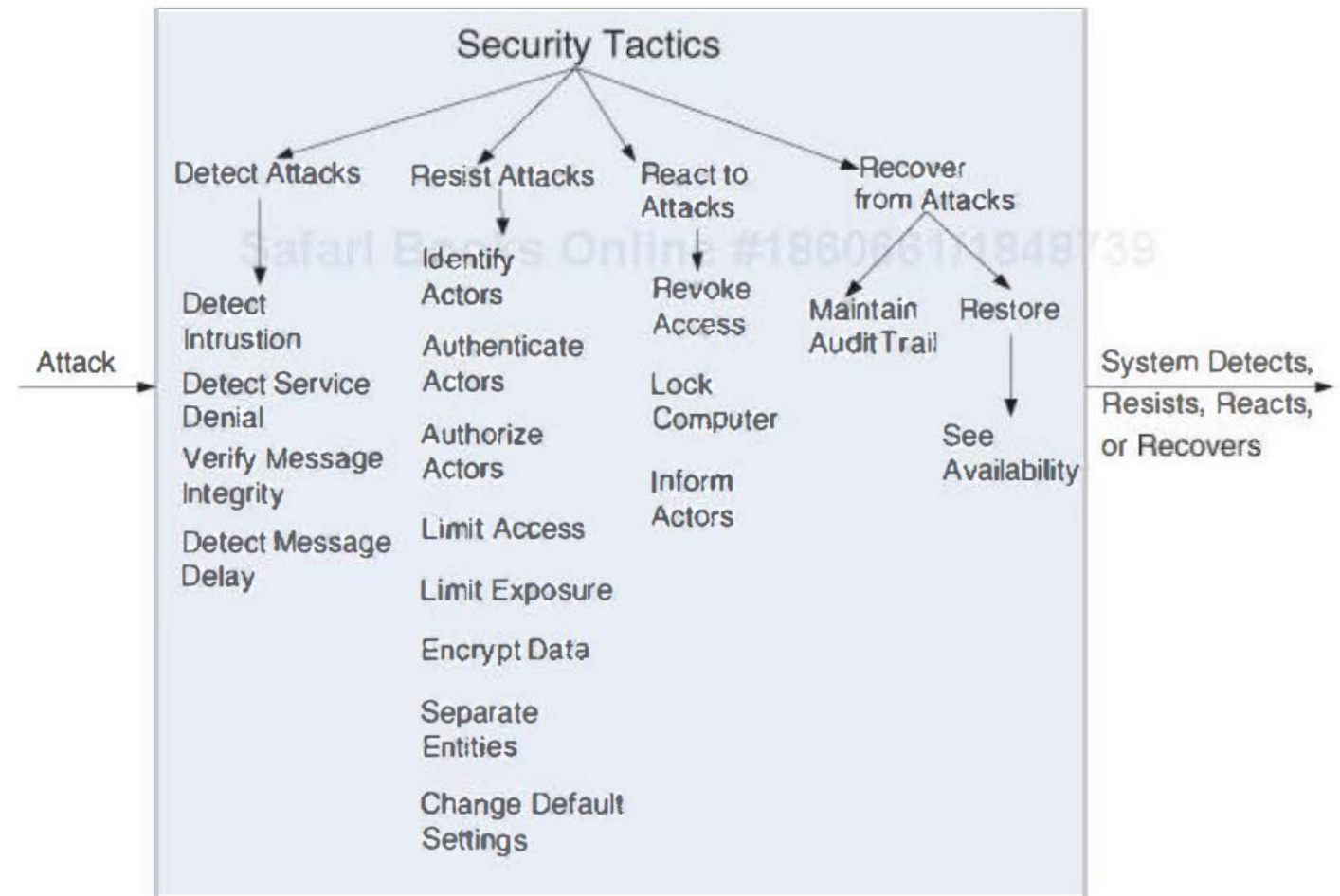


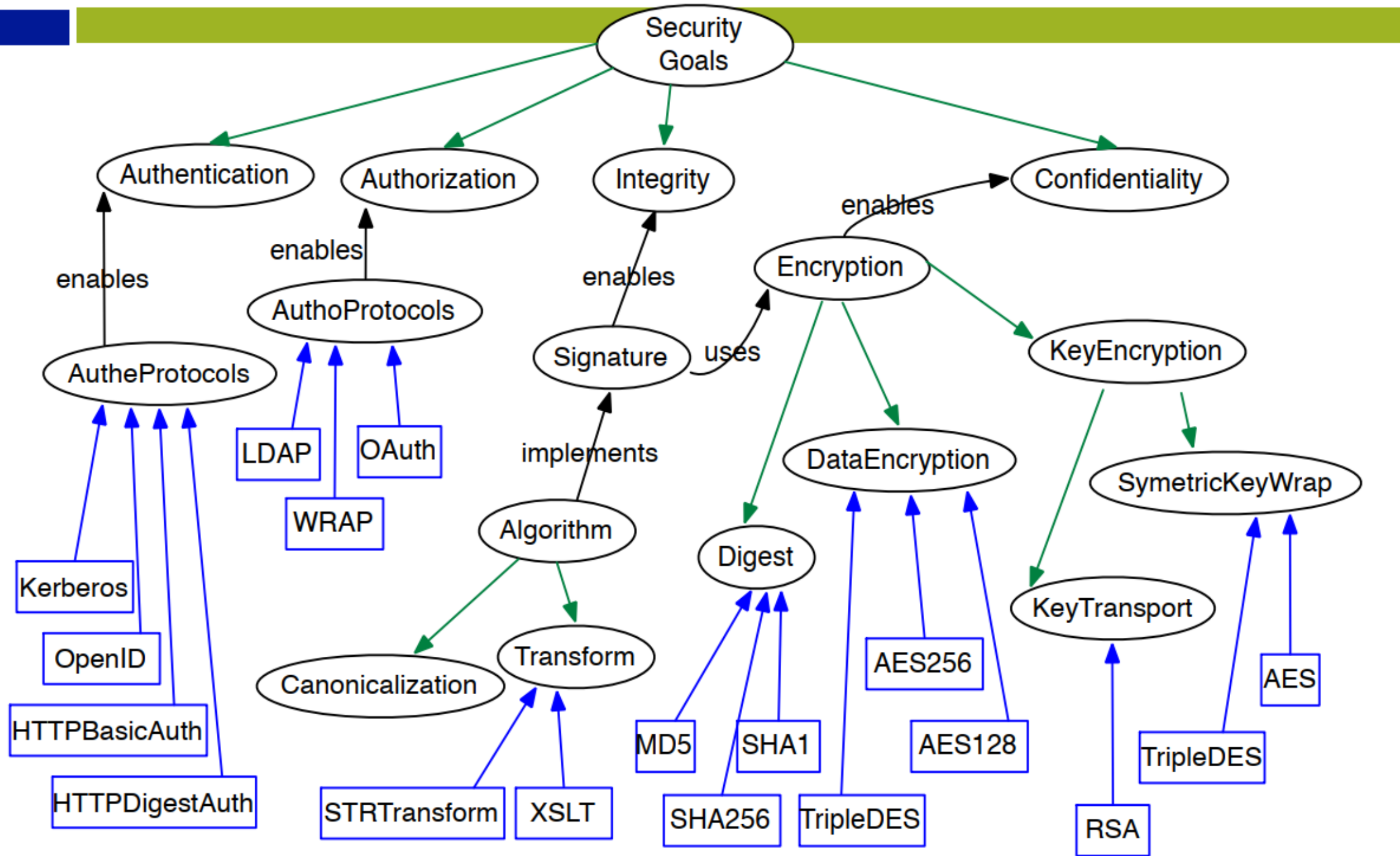
Métodos

- Limitar físicamente el acceso a usuarios confiables
- Mecanismos de hardware (ej., biométrica, llaves físicas)
- Mecanismos de sistema operativo que impone reglas a programas no confiables (ej., control de acceso basados en roles)
- Anti-virus
- Técnicas de aseguramiento de código (e.g. buffer overflow)
- Proteger C I A

Tácticas para seguridad

Bass, Kazman





Amenazas: Actores frecuentes

- Hackers individuales
 - Script kiddies
 - Aficionados
 - Lone wolves
- Agrupaciones de hackers
 - Coordinados
 - Pueden ser anónimos
- Empresas de hacking
 - NSO Group: Pegasus
- APT: Grupos State-sponsored
 - Lazarus: Korea del norte
 - APT33: Charming kitten - Iran
 - APT28: Fancy Bear - Rusia
- Estados completos: Cyberwarfare
 - US Cyber command, NSA, CIA
 - Unidad 61398 del Ejército Popular de Liberación



Los actores pueden provenir de cualquier parte



Account Fraud

Apple rooted out 428,000 developer accounts and 282 million customer accounts for fraud and abuse last year.



Protecting App Store Users: Account Fraud in 2022

428,000

developer accounts
terminated for
potentially
fraudulent activity

105,000

fraudulent developer
account creations
blocked

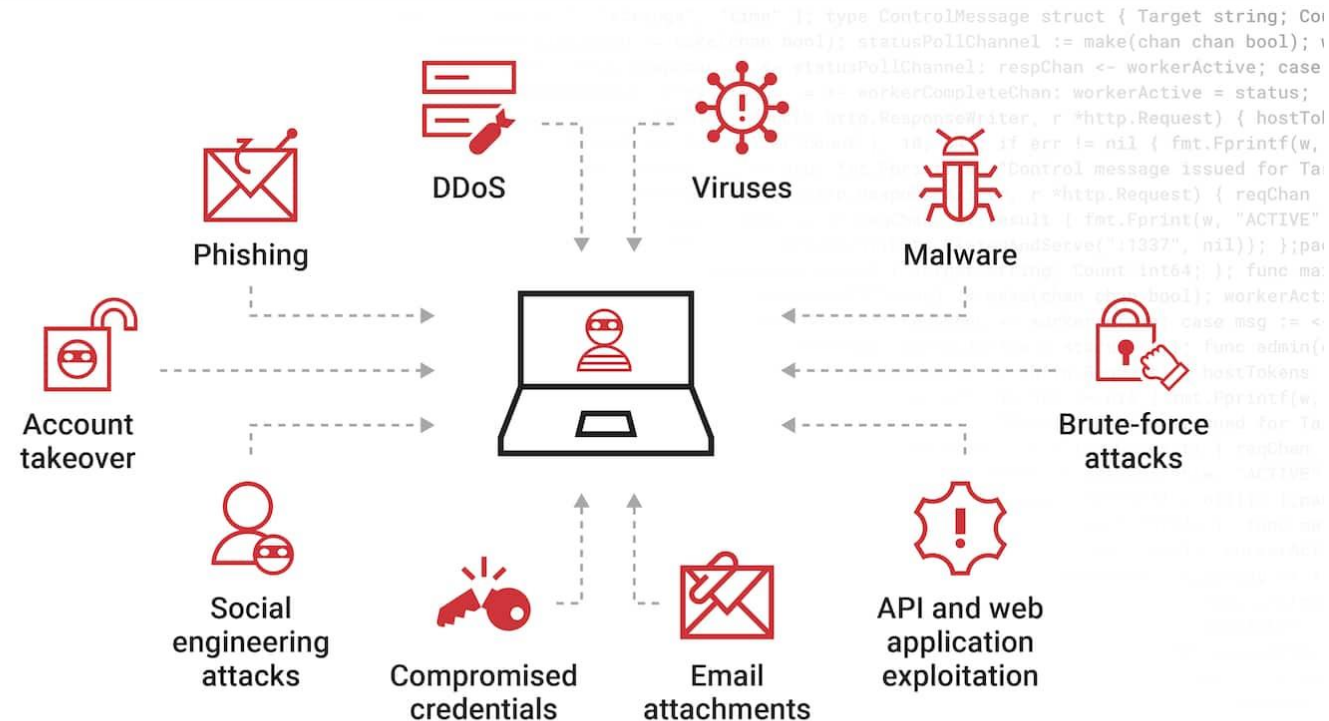
282 million

fraudulent
customer accounts
deactivated

<https://www.apple.com/newsroom/2023/05/app-store-stopped-more-than-2-billion-in-fraudulent-transactions-in-2022/>

Vectores de amenaza

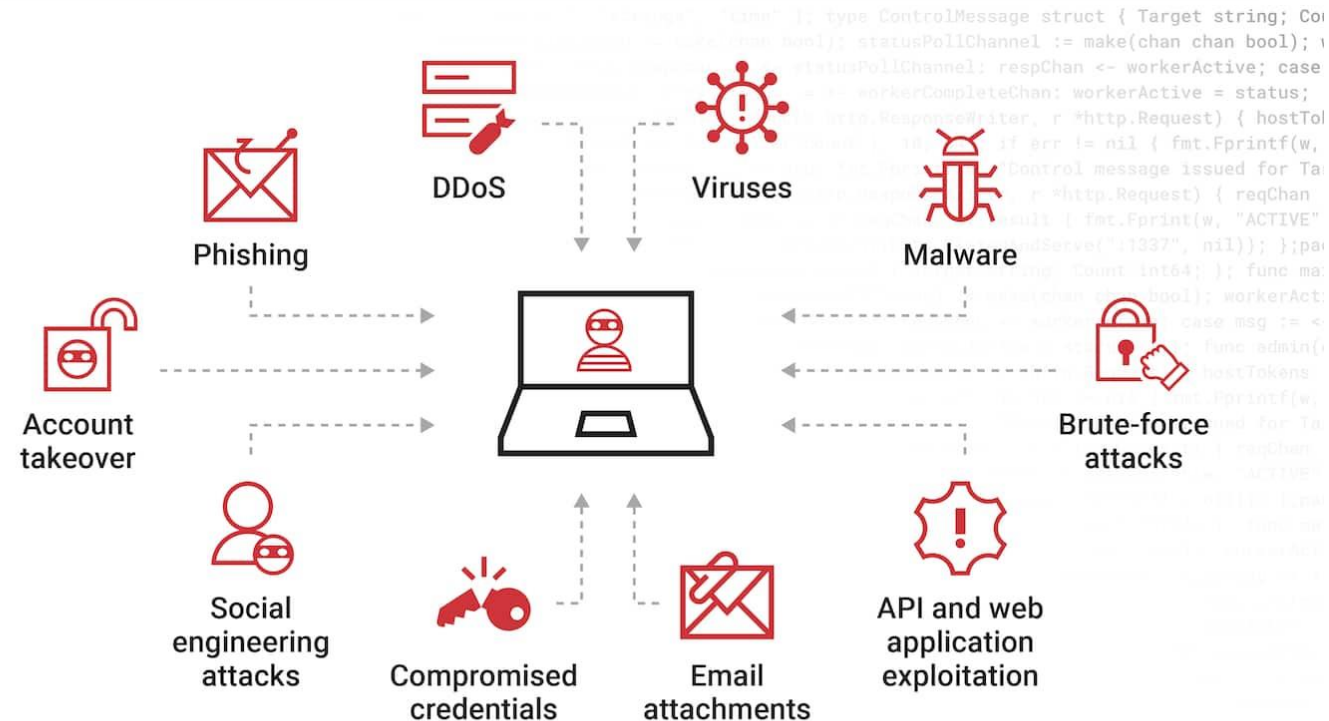
- Espacios habilitados para que actor agresivo vulnere y acceda un sistema objetivo
- Permiten acceder a un sistema vulnerando bases de seguridad de un sistema



Common types of attack vectors

Vectores de ataque

- Malware
 - Zero-day
 - Outdated
- Vulnerabilidades
 - Zero-day
 - Outdated
- Usuarios
 - Phishing
 - Ingeniería social
 - Media
 - Insiders
- MitM
- Over-factors
 - Password
 - Biometrics
 - Portables



Common types of attack vectors

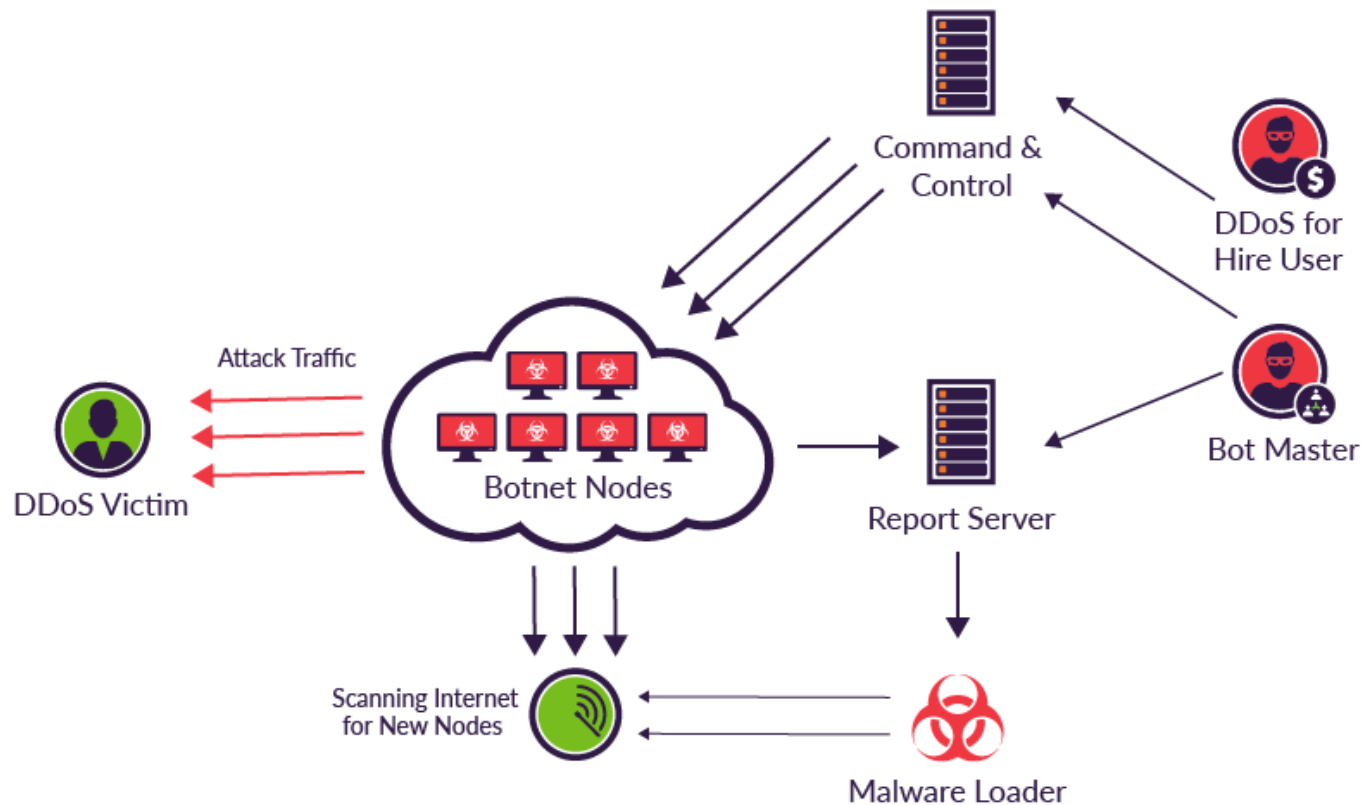


Malware

- Cualquier programa que va contra los intereses del usuario
- Usos
 - Implantación de Backdoors
 - DoS
 - DDoS
 - Vandalismo
 - Defacing
 - Ataques gubernamentales
 - Robo de recursos
 - Robo de información
 - Secuestro de información
 - Interferencia política

DDoS masivo: Mirai

Mirai at a Glance



Malware: Virus

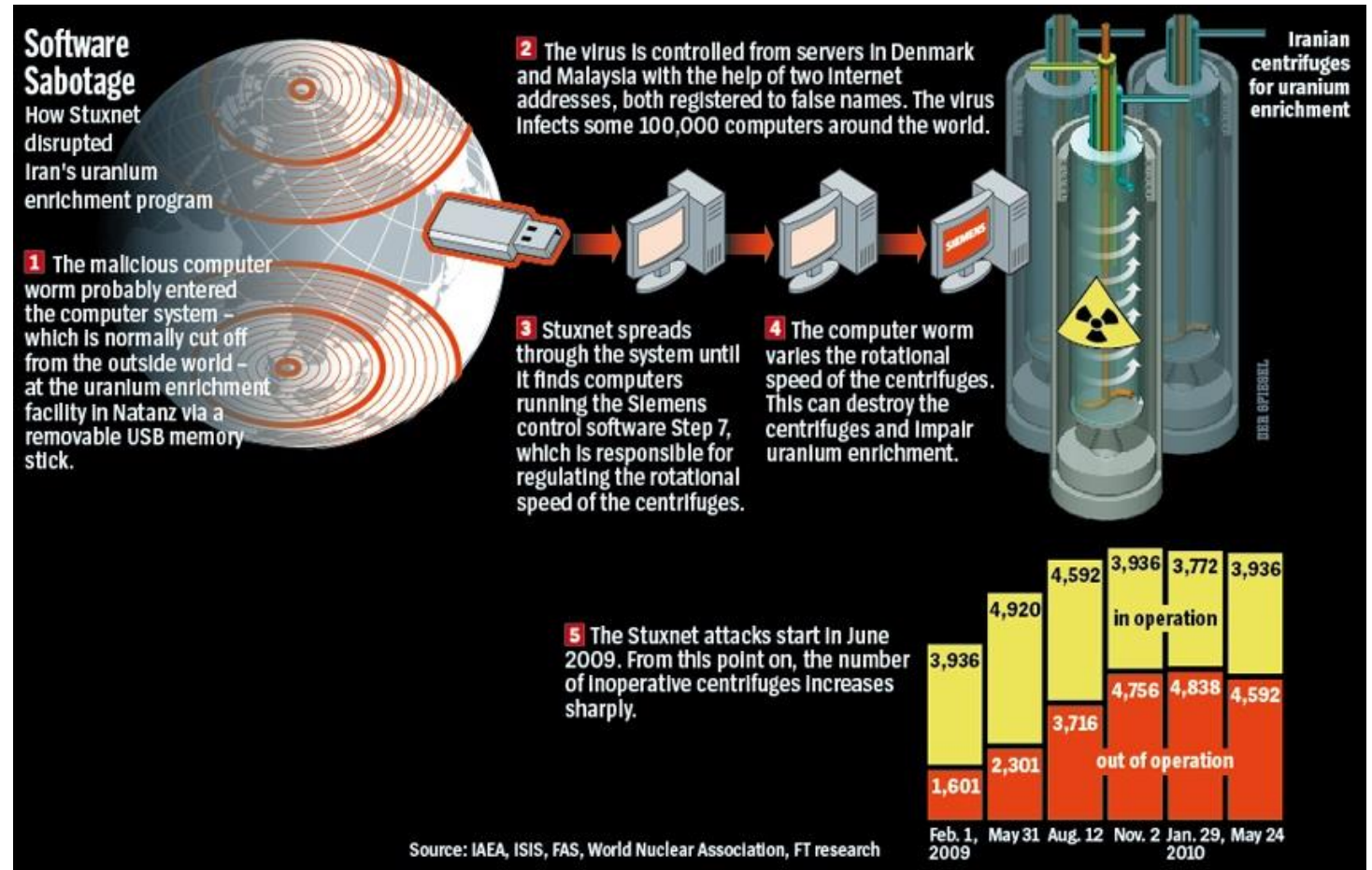
- Programa que se auto-replica con malas intenciones
- Deben ejecutarse (iniciarse) por un humano
- Tipos avanzados
 - Polimórficos: encriptan el código con una llave (firma) random y lo desenscriptan al momento de ejecutarse
 - Cada copia parte con una seed diferente para el random
 - Se puede almacenar (antivirus) las llaves o firmas conocidas de los viruses
 - Metamórficos: Cambian el código completamente al copiarse
 - Pueden interceptar lecturas al filesystem por parte de los antivirus y “simular” que no existen

Malware: Worm

- Similares a los virus, pero no necesitan ser ejecutados por personas, explotan vulnerabilidad de S.O., o de aplicaciones (JBoss, e-mail, etc.)
- Se propagan por la Web
- Usualmente inyectan más malware (payload) y generan Backdoors
 - Crea un canal de acceso encubierto para conectarse, controlar, espiar, y manipular la maquina de la víctima

Malware: Worm Stuxnet

- Supuestamente creado por USA e Israel
- Apuntaba complejos nucleares Iraníes, destruyendo centrifugas
- Realizado con inteligencia industrial de alto nivel (Sistemas Siemens y PLCs)

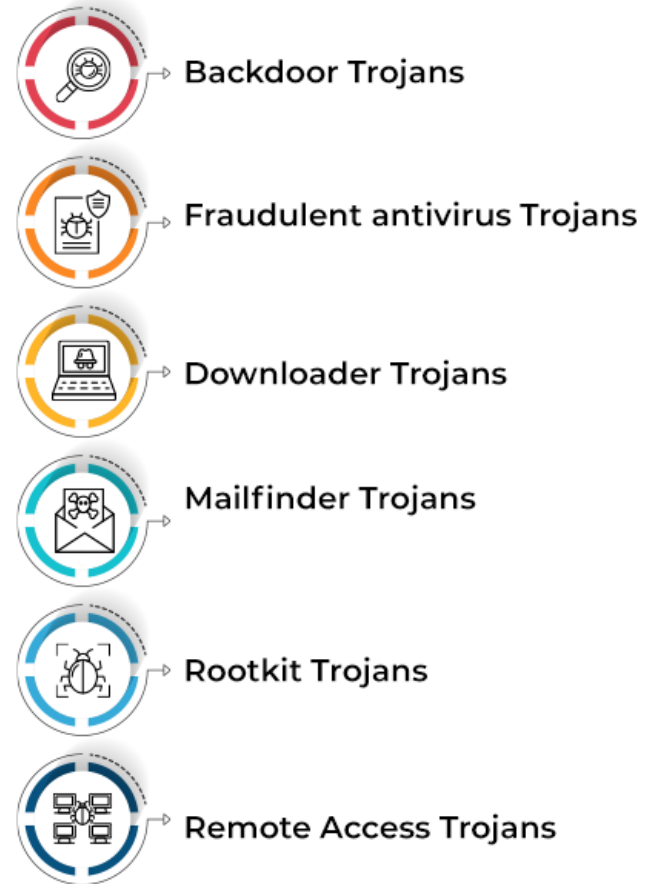


Malware: Troyano

- Incrustan código malicioso en una aplicación aparentemente inocente.
- Ej. "A Great Picture.jpg.exe"
- Muy común en casos de Phishing



EXAMPLES OF TROJAN HORSE VIRUS



2022 – Malware financiero

TOP 10 financial malware families

	Name	Verdict	%*
1	Ramnit/Nimnul	Trojan-Banker.Win32.Nimnul	33.8
2	Zbot/Zeus	Trojan-Spy.Win32.Zbot	15.6
3	CliptoShuffler	Trojan-Banker.Win32.CliptoShuffler	6.2
4	SpyEye	Trojan-Spy.Win32.SpyEye	5.5
5	Trickster/Trickbot	Trojan.Win32.Trickster	3.9
6	IcedID	Trojan-Banker.Win32.IcedID	3.6
7	RTM	Trojan-Banker.Win32.RTM	2.5
8	Gozi	Trojan-Spy.Win32.Ursnif	2.2
9	Cridex/Dridex	Backdoor.Win32.Cridex	2.2
10	BitStealer	Trojan-Banker.MSIL.BitStealer.gen	1.5

* Unique users attacked by this malware as a percentage of all users attacked by financial malware.

Malware: Otros

- Ransomware
 - Secuestro de la data del usuario mediante criptografía
 - Se demanda un rescate por la data
 - Usualmente pagado en BTC
- Adware
 - Programa que fuerza llamadas a publicidad (advertising) no intencional
 - Objetivo: Perfilar al usuario (hábitos de browsing y compra)
- Dropper
 - Descarga más malware a un sistema dado y lo instala
- Rootkit
 - Proporciona acceso root a código arbitrario
- Sticky software
 - Impiden al usuario desinstalarlo de manera simple

El Ransomware al mainstream: WannaCry

- Mayo 2017
- Secuestro de cientos de miles
- Uso de vulnerabilidad EternalBlue
 - Liberada por "Shadow brokers"
- Facilitado por la irrupción del bitcoin al mainstream



Disponibilidad de Malware

“Categorización” de hackers:

- The Ethical Hacker (White hat)
- Cracker
- Grey hat
- Script kiddies
- Hacktivist
- Phreaker

Herramientas “recomendadas”:

- Evasion
 - Metasploit (freemium)
- Vulnerabilidades
 - Intruder (free-trial, barata infra)
 - Sn1per (pentests)
 - Cain & Abel (man in the middle)
 - ZAP (ZedAttackProxy - OWASP)
- Redes
 - Wireshark
 - Aircrack-ng
 - Nmap (scan)
- Análisis de apps
 - Kiuwan (\$)
- Passwords
 - John the ripper
 - THC Hydra

<https://gbhackers.com/hacking-tools-list/>

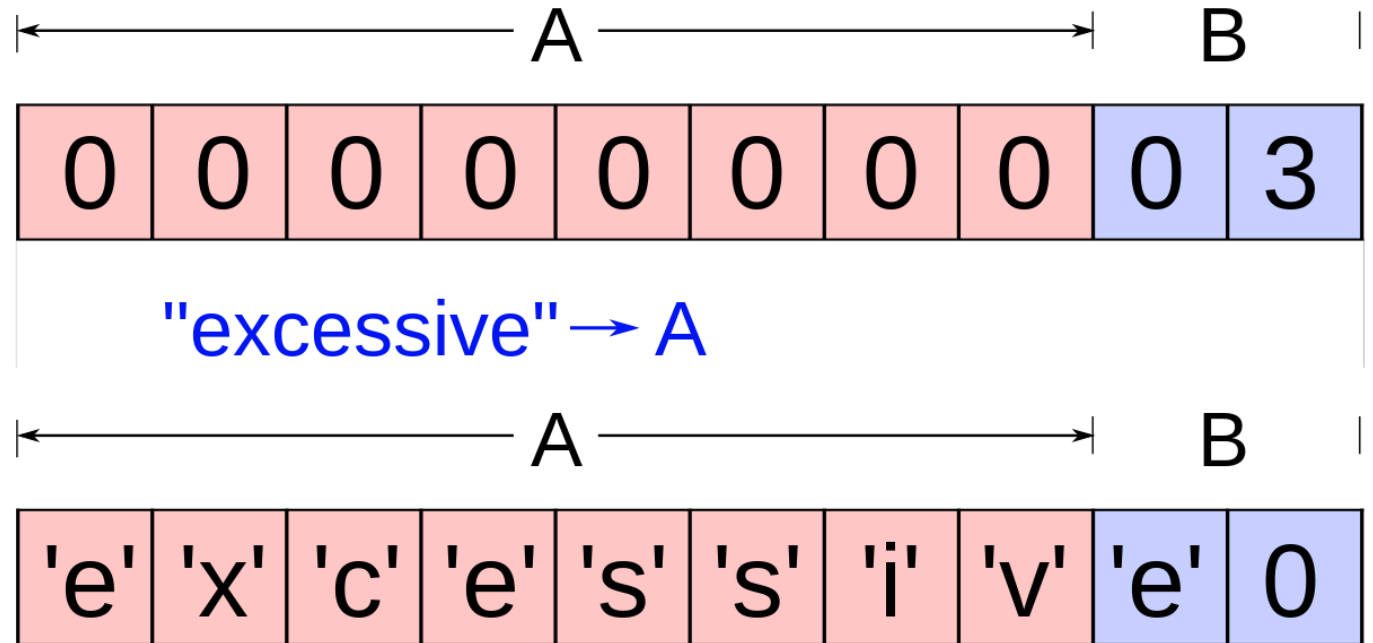
Fuentes de vulnerabilidad

- Software
 - Código
 - Web
- Comunicación
 - MITM
 - Comunicación abierta
- Humanos
 - Phishing
 - Atacantes



Vulnerabilidades: Software

- Buffer overflow
 - Overread
 - Overwrite
- Heap overflow
- Format string
 - En output
- 3rd party libraries / plugins
- Open source
 - Debido a pobre mantención o bugs
- Software desactualizado
- Lenguajes “unsafe”
 - C: malloc, free



https://es.m.wikipedia.org/wiki/Archivo:Buffer_overflow_basic_example.svg

Vulnerabilidades: Software

- Testing deficiente
- Integración de código no testeado
- Colaboradores maliciosos o con intenciones de sabotaje
 - E.g. Faker
- Repositorios de software bajo ataque
 - NPM 15000+ paquetes spam en feb 2023

PyPI new user and new project registrations temporarily suspended.

Incident Report for Python Infrastructure

Resolved

Suspension has been lifted.

Posted 13 hours ago. May 21, 2023 - 21:57 UTC

Identified

New user and new project name registration on PyPI is temporarily suspended. The volume of malicious users and malicious projects being created on the index in the past week has outpaced our ability to respond to it in a timely fashion, especially with multiple PyPI administrators on leave.

While we re-group over the weekend, new user and new project registration is temporarily suspended.

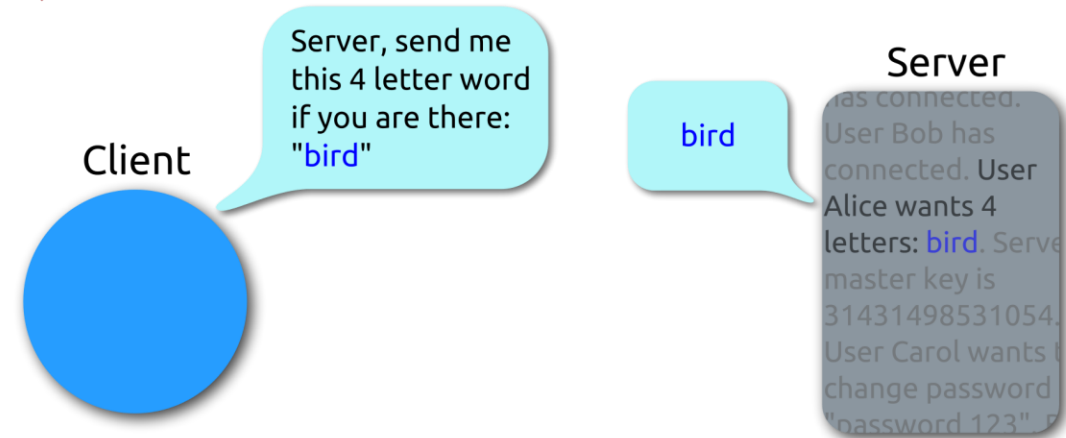
Posted 2 days ago. May 20, 2023 - 16:02 UTC

This incident affected: PyPI (pypi.org - General).

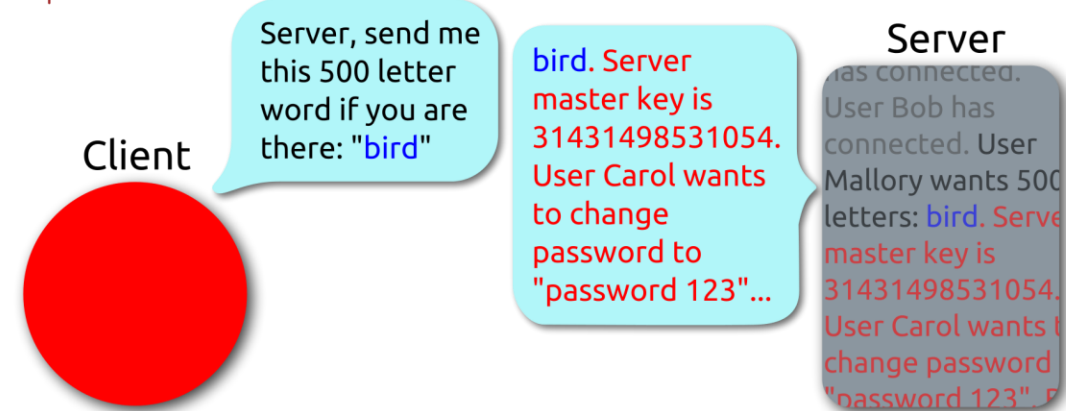
Caso: Heartbleed

- Explotación de buffer overread
- Falta de chequeos de memoria en lenguaje de “bajo” nivel
- Vivió 2 años de forma salvaje
- Falta de mecanismos de actualización permitió que la falla viviera varios años más

Heartbeat – Normal usage



Heartbeat – Malicious usage



Vulnerabilidades: Protocolos

- Spoofing
 - IP, UDP, Conexión TCP

TCP Sequence Number

Internet Routing

ICMP Redirect

PoD (Ping of Death)

ARP Poisoning

TCP SYN Flood

IP Fragmentation

WiFi Deauth

UDP Port DoS (Denial-ofService)

Random Port Scanning

Packet sniffers (Promiscuous mode)

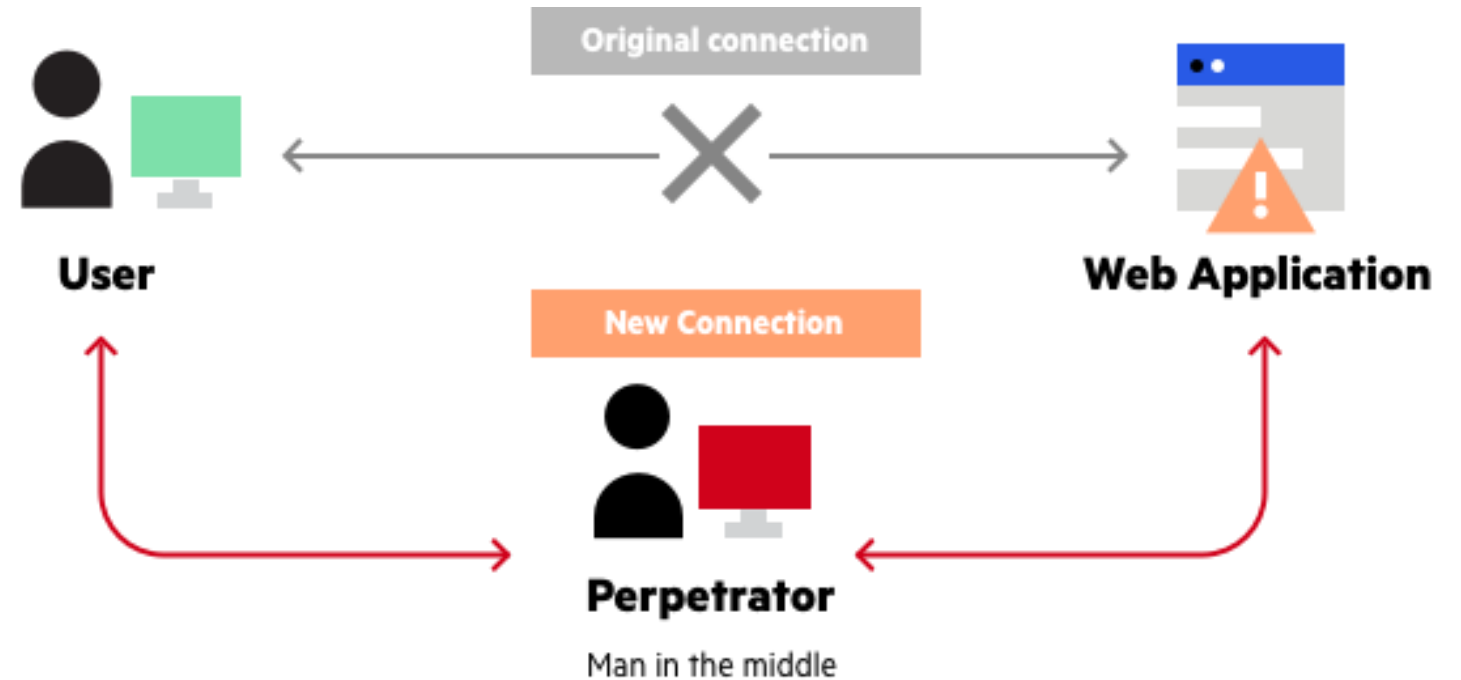
Connection hijacking

Security through obfuscation

- “Asegurar” un sistema ocultando el funcionamiento de alguna de sus partes
- Solo una medida menor
 - “Lo secreto tarde o temprano se revela”
 - Usualmente proporciona seguridad engañosa
- Ejemplo
 - Puertos ocultos
 - Dominios ocultos
 - Protocolos propietarios
 - Scrambling
 - Documentación oculta

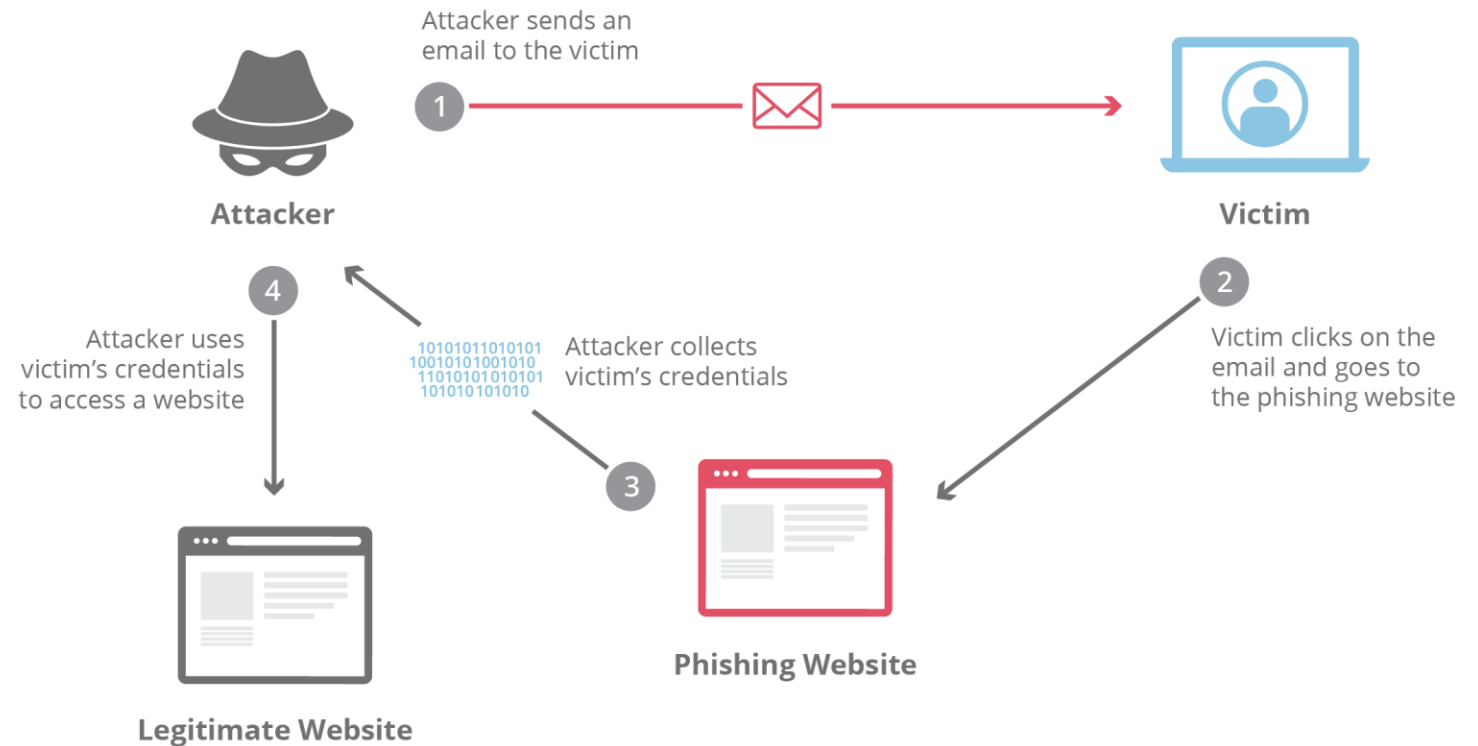
MITM attacks

- Intercepción de comunicación entre dos entidades sin su conocimiento
- Componentes
 - Intercepción
 - Manipulación
 - Suplantación de identidad
- Evitar canales abiertos (WiFi, redes públicas)



Vulnerabilidades: Usuarios

- Usualmente un punto difícil de asegurar
- Puede vulnerar sistemas teóricamente muy seguros
- Requiere educación y enforcement
 - Políticas empresariales
 - Protección de endpoints
 - Charlas e incentivos



Vulnerabilidades comunes: Usuario

- Anotar passwords en post-its
- Compartir información confidencial en sistemas públicos
- Contraseñas fáciles
- Asignación deficiente de roles
- Errores en configuración
- Ingeniería social
- No backups de datos
- Saltarse normas de seguridad para “acelerar el trabajo”
- Descuido de documentos e información

Social engineering

- El arte de manipular a las personas para que divulguen información confidencial
- **Pretexto:** Crear un escenario falso, impersonar, etc.
- **Desvío:** Engañar alguien de entregar algo a quien no corresponde (pidieron que lo entregaran en otro sitio, vengo a recogerlo de urgencia, herencia, etc.)
- **Phishing:** Obtener información privada de manera fraudulenta
- **Piggybacking:** Aprovecharse de los permisos de alguien para colarse a continuación

Sender 49226156525035506892912677635  Spam 



Leonard Leannon <leonardleannon178@gmail.com>

vie, 19 may, 16:11 (hace 3 días)



para quillxink, veilsdad, mi, suryan.alex, taylorswiftisme123, ricardobenfatti, yhall051681, jdlhma, jennyjenkins, narutoarmstrong, seanisthegood, btenybe ▼

¿Por qué está en la carpeta Spam este mensaje? Es similar a mensajes que se identificaron como spam en el pasado.

Informar que no es spam



Your account balance has received an increase: the funds have been credited.
Account termination reminder!!! kpbp4002
Please withdraw your savings. 36.357
Support Jeff Hall L ID 561 EO
We are going reply you inside some seconds
Sender: 99dy9***39
Authorization code: 1256i24
TIN: 39854604
BIC: 1980nm99150110444265259531539

← Responder

↶ Responder a todos

→ Reenviar

Phishing

- Ataque que se camufla en un medio de comunicación específico
- Se disfraza de necesidad o requerimiento de un usuario
- Canales diversos
 - Email
 - SMS
 - Mensajería
 - Redes sociales
- Variantes
 - Spear: Individuos
 - Whaling: VIPs y \$\$\$



CONASET - Notificacion

Informe Online sobre multas y sanciones de transito

Estimado Contribuyente: [Redacted]

Si usted no regulariza las infracciones correspondientes en los proximos 10 días a partir de la fecha de emision de este comunicado, su vehiculo sera informado como deudor.

Infracciones al dia 10/04/2023 Tiempo '15:27:39'

Siga los archivos adjuntos a continuación para ver los detalles de la infracción de tránsito

Infracciones	Acceso	Detalle
Estacionemtno no permitido - Girar en lugar prohibido Ir a Trámite en línea Más información		

(Para acceder al documento electronico recuerde que la version de este documento es unicamente para PC no funciona en dispositivos moviles.)

Para consultar tu sanción, accede a Más información arriba o Accede a Trámite online y regulariza tu situación ante las autoridades.

El propietario del vehiculo queda notificado por este medio

La informacion contenida en el sistema es generada y respostada por los organismos de transito

Comisión nacional de Seguridad de Tránsito

Ejemplos

Nice to Know You

Naomi Surugaba [azlin@moa.gov.my]

Inbox

I am Miss Naomi Surugaba a daughter to late Al-badari Surugaba of Libya whom was murdered during the recent civil war in Libya in March 2011, before his death my late father was a strong supporter and a member of late Moammar Gadhafi Government in Tripoli. Meanwhile before the incident, my late Father came to Cotonou Benin republic with the sum of USD4, 200,000.00 (US\$4.2M) which he deposited in a Bank here in Cotonou Benin Republic West Africa for safe keeping.

I am here seeking for an avenue to transfer the fund to you in only you're reliable and trustworthy person to investment the fund. I am here in Benin Republic because of the death of



CTV Edmonton
@ctvedmonton

Follow

\$43M in cash found in empty Nigerian apartment ctvnews.ca/business/43m-i ...



RETWEETS
2,845

LIKES
3,251

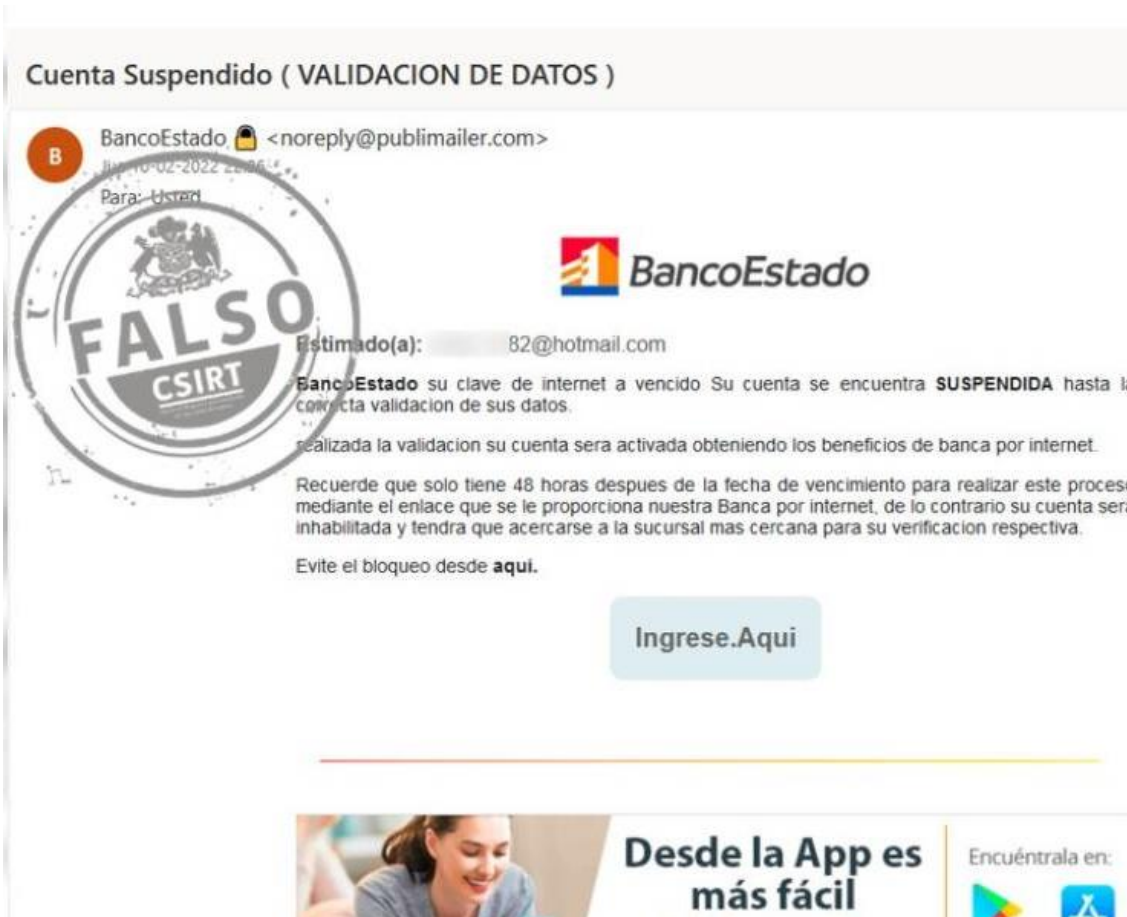


Nuck Fuggets
@MatHouchens

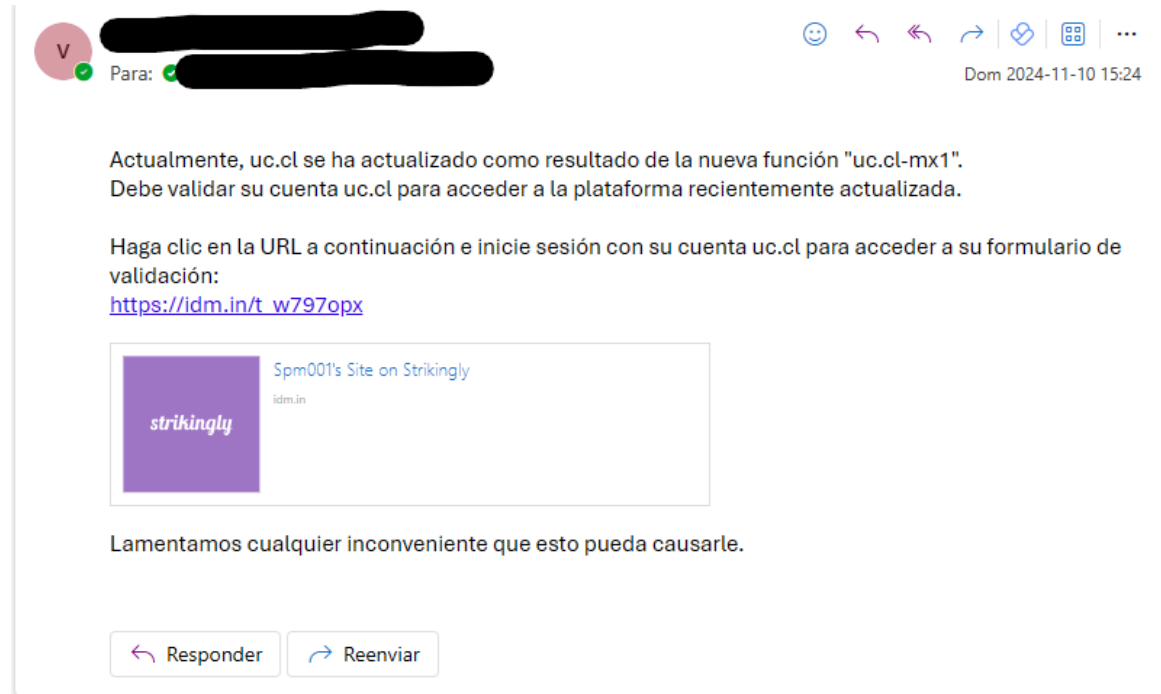
Follow

Poor guy probably spent the past decade trying to share it but no one ever replied to his email.

Ejemplos

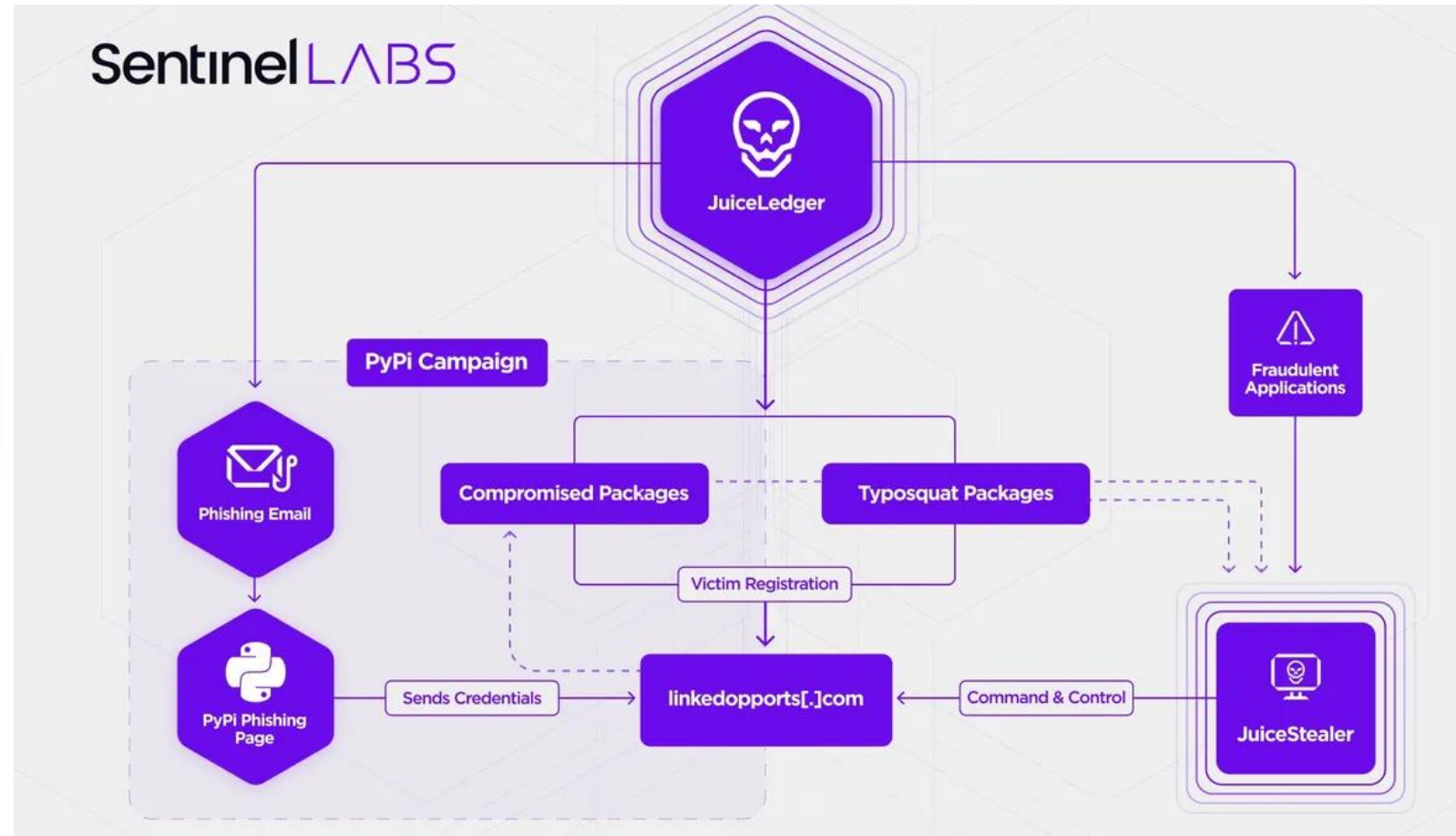


Ejemplos



Supply chain attack

- Ataque dirigido a cualquier proveedor para un sistema dado
 - Paquetes
 - COTS
 - Tech subyacente
 - Hardware
- Altamente efectivo y altamente explotado



PyPI new user and new project registrations temporarily suspended.

Incident Report for Python Infrastructure

Resolved

Suspension has been lifted.

Posted 13 hours ago. May 21, 2023 - 21:57 UTC

Identified

New user and new project name registration on PyPI is temporarily suspended. The volume of malicious users and malicious projects being created on the index in the past week has outpaced our ability to respond to it in a timely fashion, especially with multiple PyPI administrators on leave.

While we re-group over the weekend, new user and new project registration is temporarily suspended.

Posted 2 days ago. May 20, 2023 - 16:02 UTC

This incident affected: PyPI (pypi.org - General).

<https://checkmarx.com/blog/this-new-supply-chain-attack-technique-can-trojanize-all-your-cli-commands/>

Checkmarx

Home > Blog > This New Supply Chain Attack Technique Can Trojanize All Your CLI Command

Blog

This New Supply Chain Attack Technique Can Trojanize All Your CLI Commands

 Yehuda Gelb

 Elad Rapoport

14 min.

October 14, 2024

AppSec

Checkmarx Security Research Team

Open Source Security

Supply Chain Security



COMMAND-JACKING

npm, docker, curl, cat, aws, pip

CHECKMARX ZERO

The open source ecosystem, due to its widespread adoption, has become a prime target for supply chain attacks. Malicious actors often exploit built-in features of open source packages to automatically distribute and execute harmful code. They particularly favor two techniques: Automatic, preinstall scripts that execute upon package installation, and seemingly innocent

SOLARWINDS ATTACK PATH

LEVEL 1 Orion Software Pipeline Infection



CI/CD
Pipeline
Compromised



Trojan Deployed
to Orion
Customers

LEVEL 2 Target SolarWinds Customers



12-14 Day
Dormant
Period



Command
& Control



Reconnaissance

LEVEL 3 Privilege Escalation to High Value Assets



Privilege
Escalation



Fortify
Access



Bypass
MFA



Target
Reached

CVE-2024-3094 Detail

MODIFIED

This vulnerability has been modified since it was last analyzed by the NVD. It is awaiting reanalysis which may result in further changes to the information provided.

Description

Malicious code was discovered in the upstream tarballs of xz, starting with version 5.6.0. Through a series of complex obfuscations, the liblzma build process extracts a prebuilt object file from a disguised test file existing in the source code, which is then used to modify specific functions in the liblzma code. This results in a modified liblzma library that can be used by any software linked against this library, intercepting and modifying the data interaction with this library.

Metrics

CVSS Version 4.0

CVSS Version 3.x

CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:



CNA: Red Hat, Inc.

Base Score: 10.0 CRITICAL

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Fixed In Version:

Doc Type: ⓘ If docs needed, set a value

Doc Text: ⓘ Malicious code was discovered in the upstream tarballs of xz, starting with version 5.6.0. Through a series of complex obfuscations, the liblzma build process extracts a prebuilt object file from a disguised test file existing in the source code, which is then used to modify specific functions in the liblzma code. This results in a modified liblzma library that can be used by any software linked against this library, intercepting and modifying the data interaction with this library.



Andres FreundTec

@AndresFreundTec@mastodon.social

I was doing some micro-benchmarking at the time, needed to quiesce the system to reduce noise. Saw sshd processes were using a surprising amount of CPU, despite immediately failing because of wrong usernames etc. Profiled sshd, showing lots of cpu time in liblzma, with perf unable to attribute it to a symbol. Got suspicious. Recalled that I had seen an odd valgrind complaint in automated testing of postgres, a few weeks earlier, after package updates.

Really required a lot of coincidences.

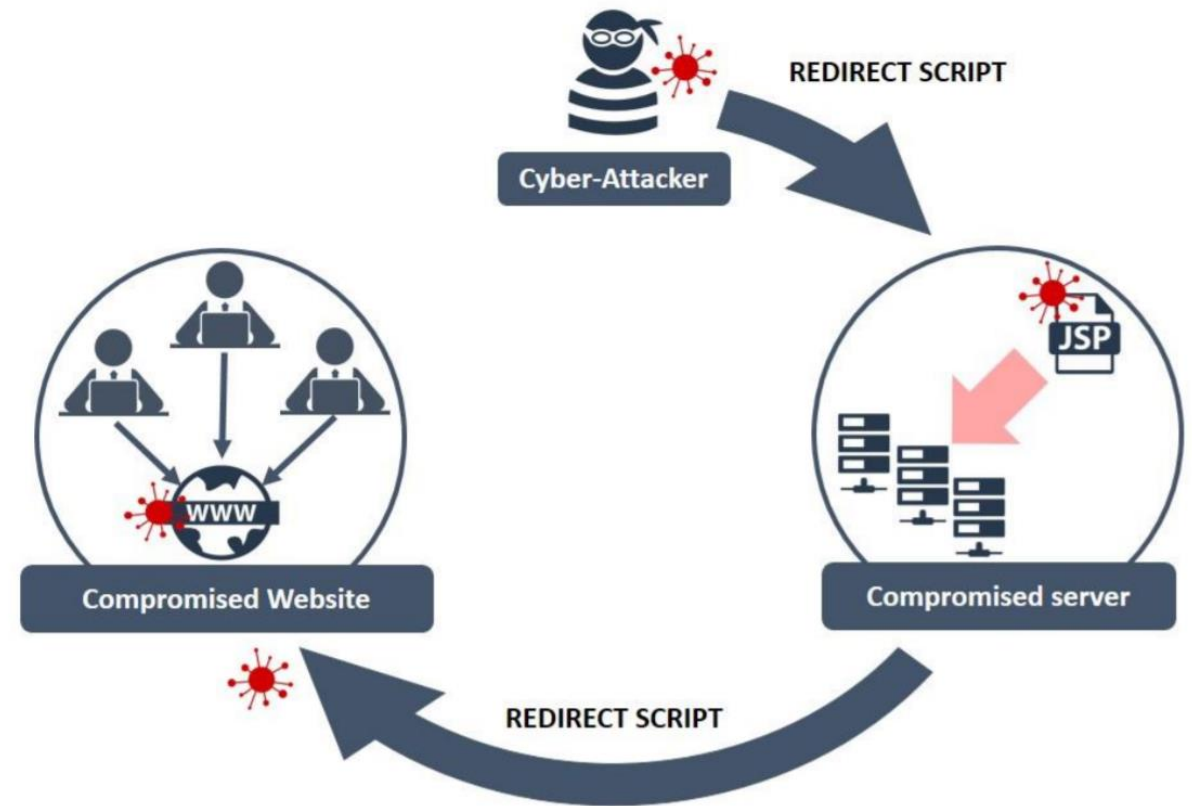
Mar 29, 2024, 18:32

816 retweets

<https://www.youtube.com/watch?v=bS9em7Bg0iU>

Watering hole attack

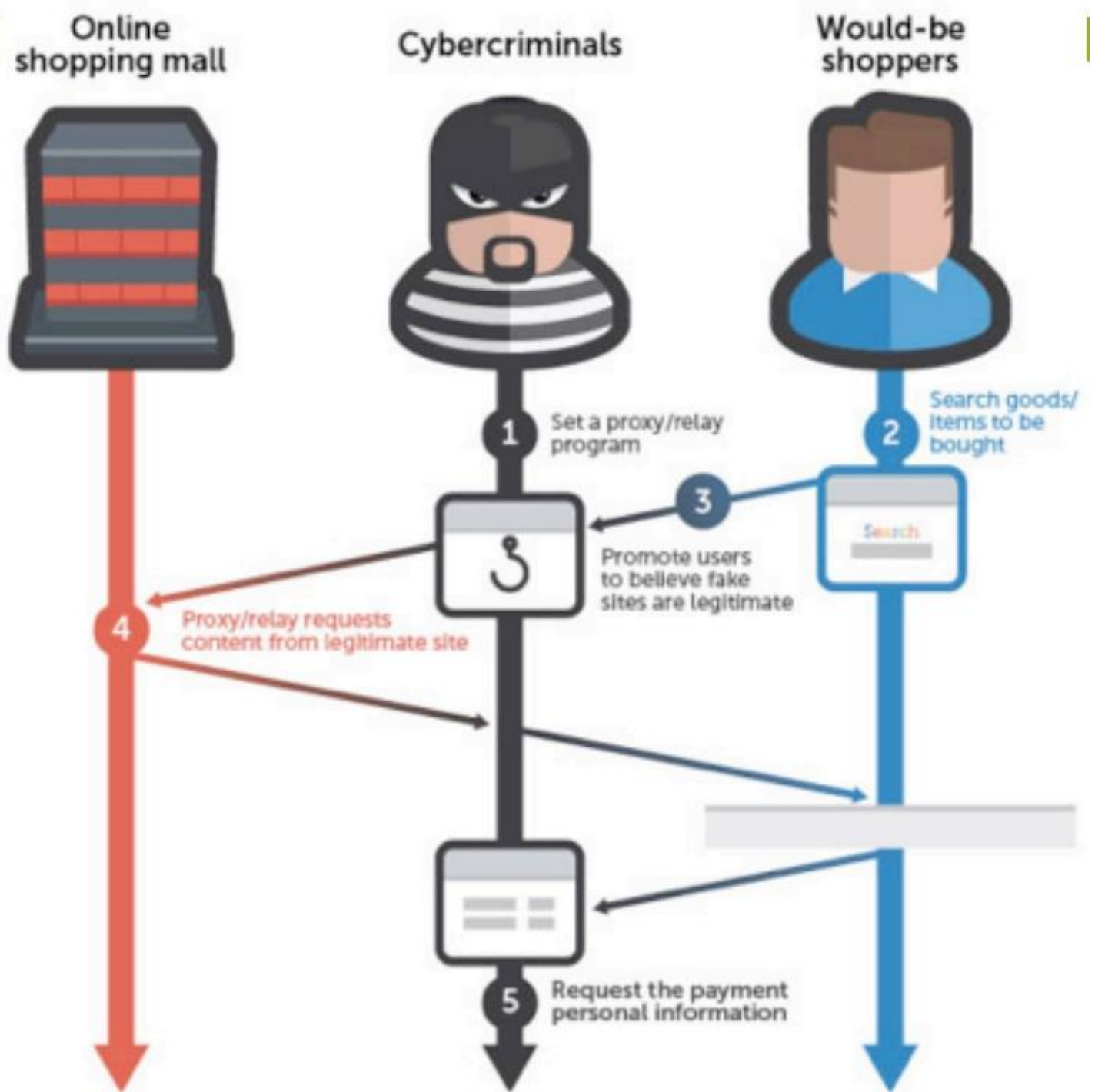
- Ataque dirigido a una organización
- Se envenena un sitio web visitado por un grupo objetivo (e.g. empresa, org)
- Compromete una fuente creíble



Example 4: Watering Hole Attack

<https://www.ncsc.gov.uk/collection/supply-chain-security/watering-hole-attacks>

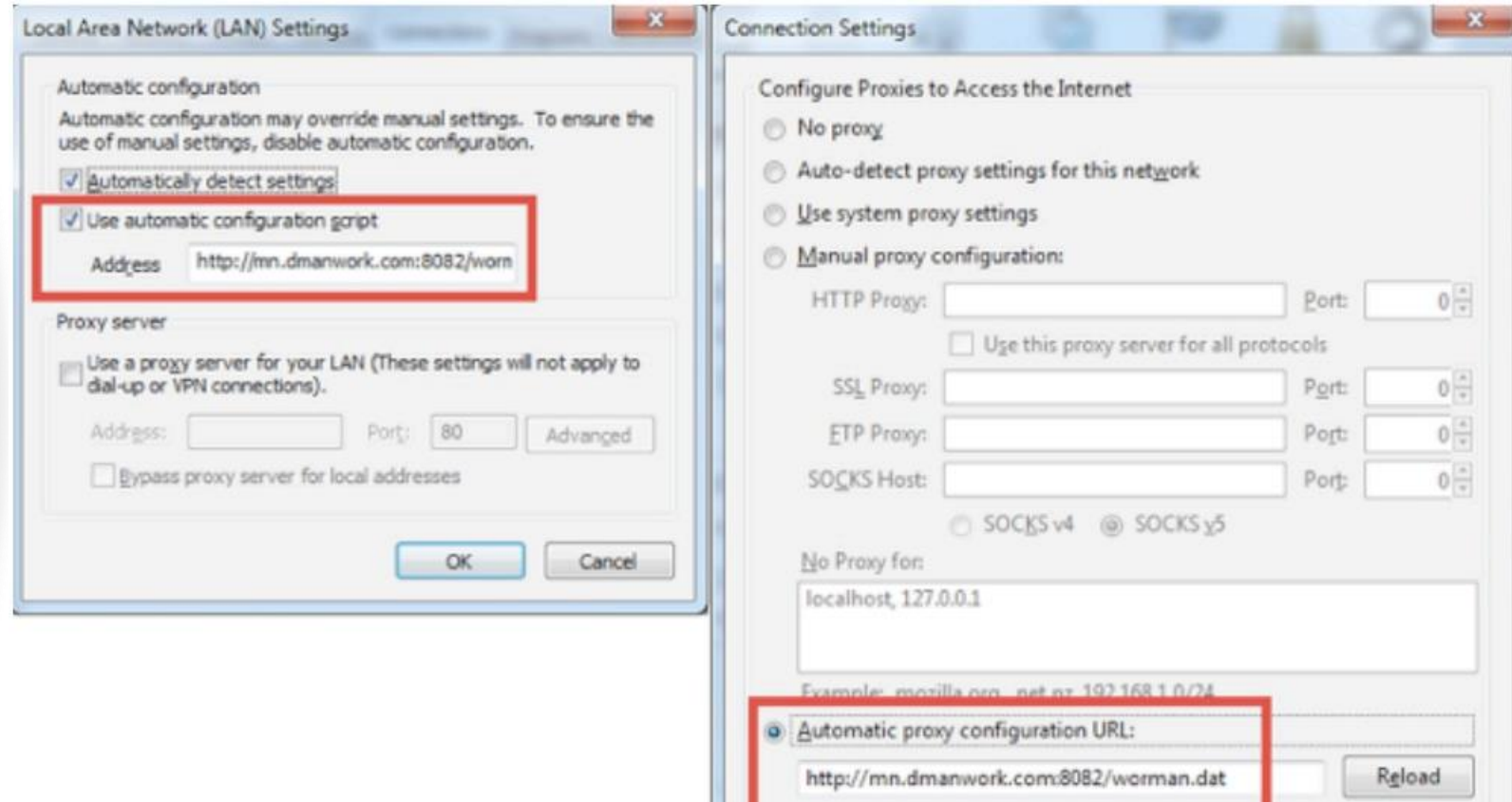
Proxy phishing



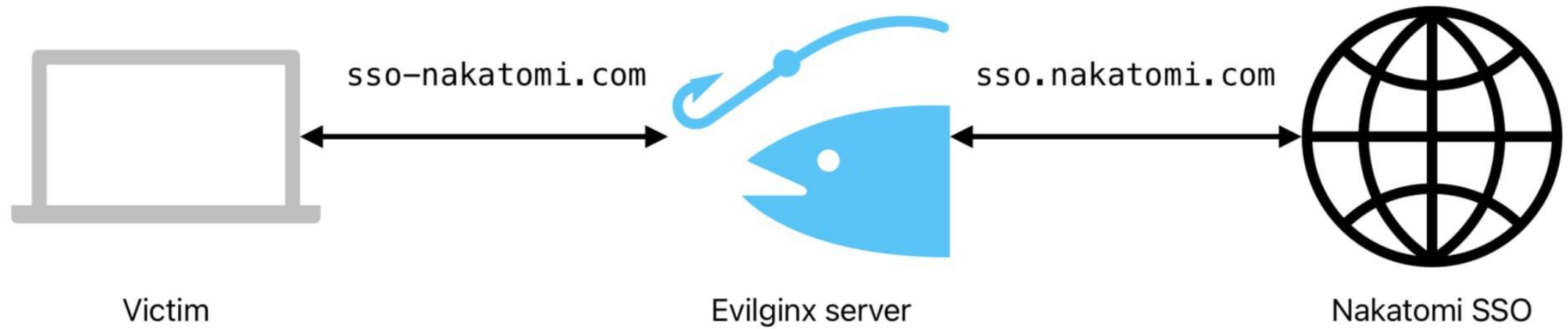
Proxy phishing

<http://www.kahusecurity.com/2014/vbe-script-leads-to-bank-fraud/>

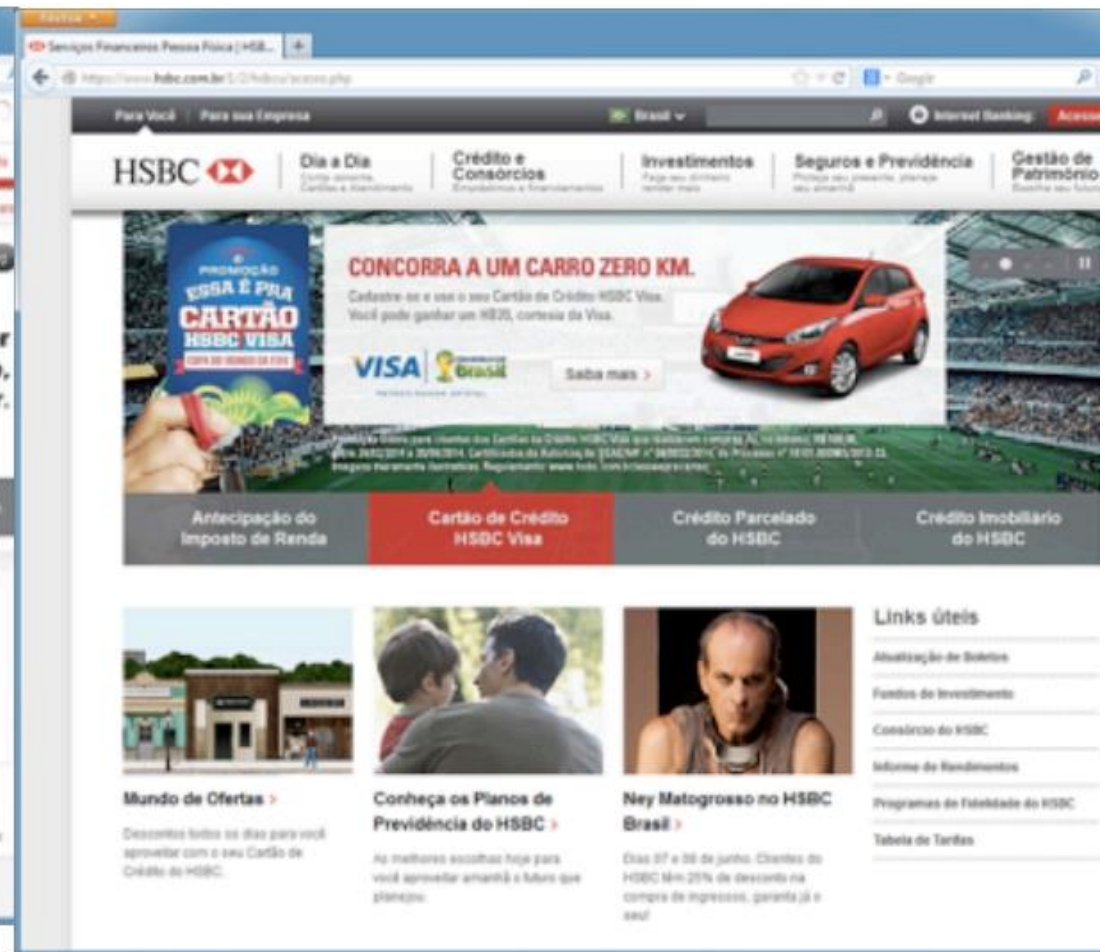
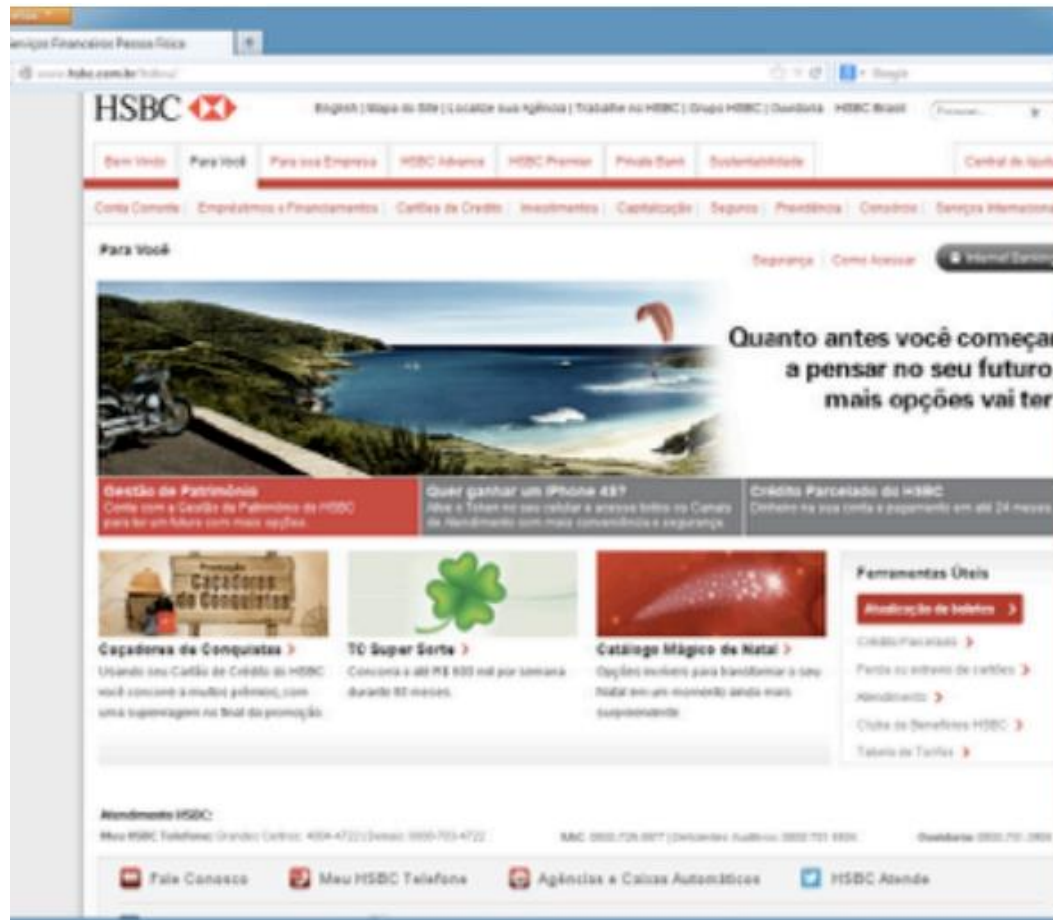
- (2013-2014) Script VBE malicioso que cambia los proxies



Proxy Phishing



Proxy Phishing: Resultados



Tracking

- Muchos sitios pueden hacer registro excesivo de los movimientos de los usuarios
- Función de los proxys:
 - Proteger privacidad
 - Ocultar la dirección IP del cliente
 - Remover información de los Headers HTTP
 - Remover cookies o eliminar las cookies falsas (hay registros)
 - Generar "ruido" para distorsionar el perfil del usuario
- Niveles
 - Browser (TrackMeNot)
 - Redes locales (GoogleSharing, Tor)
 - Web: Proxies anonimizadores

Privacy Sandbox Initiative: Google to Phase Out Third-Party Cookies Starting 2024

May 19, 2023  Ravie Lakshmanan

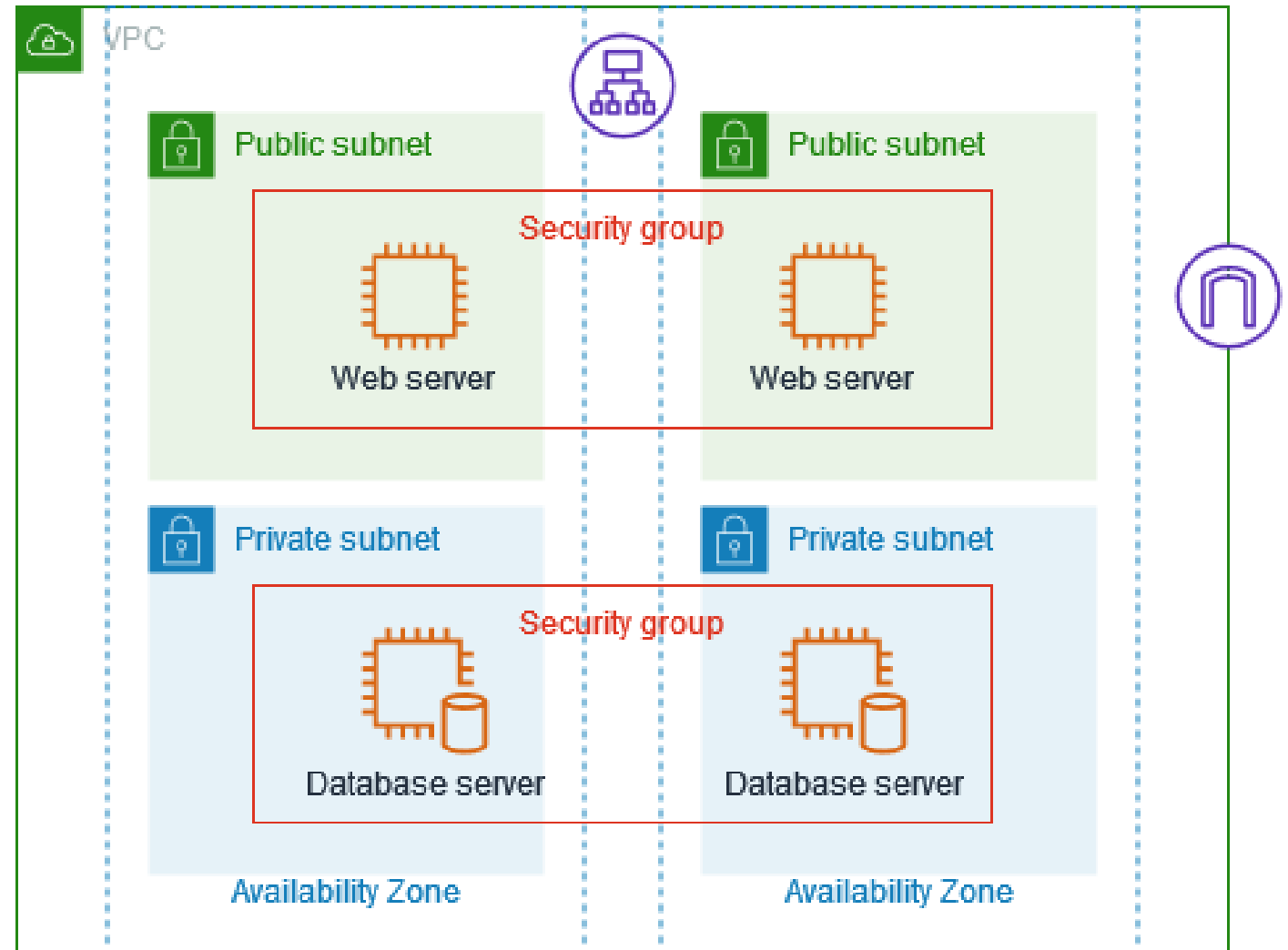


Google has announced plans to officially flip the switch on its twice-delayed **Privacy Sandbox** initiatives as it slowly works its way to deprecate support for third-party cookies in Chrome browser.

To that end, the search and advertising giant said it intends to phase out third-party cookies for 1% of Chrome users globally in the first quarter of 2024.

Vulnerabilidades: Infraestructura/ deployment

- Servidores con servicios innecesarios u obsoletos
- Control de acceso mal desplegado (IAM)
- APIs no aseguradas
- Red mal configurada
 - Puertos innecesariamente abiertos
 - Rangos públicos
- Logging deficiente
- Almacenamiento de datos inseguro

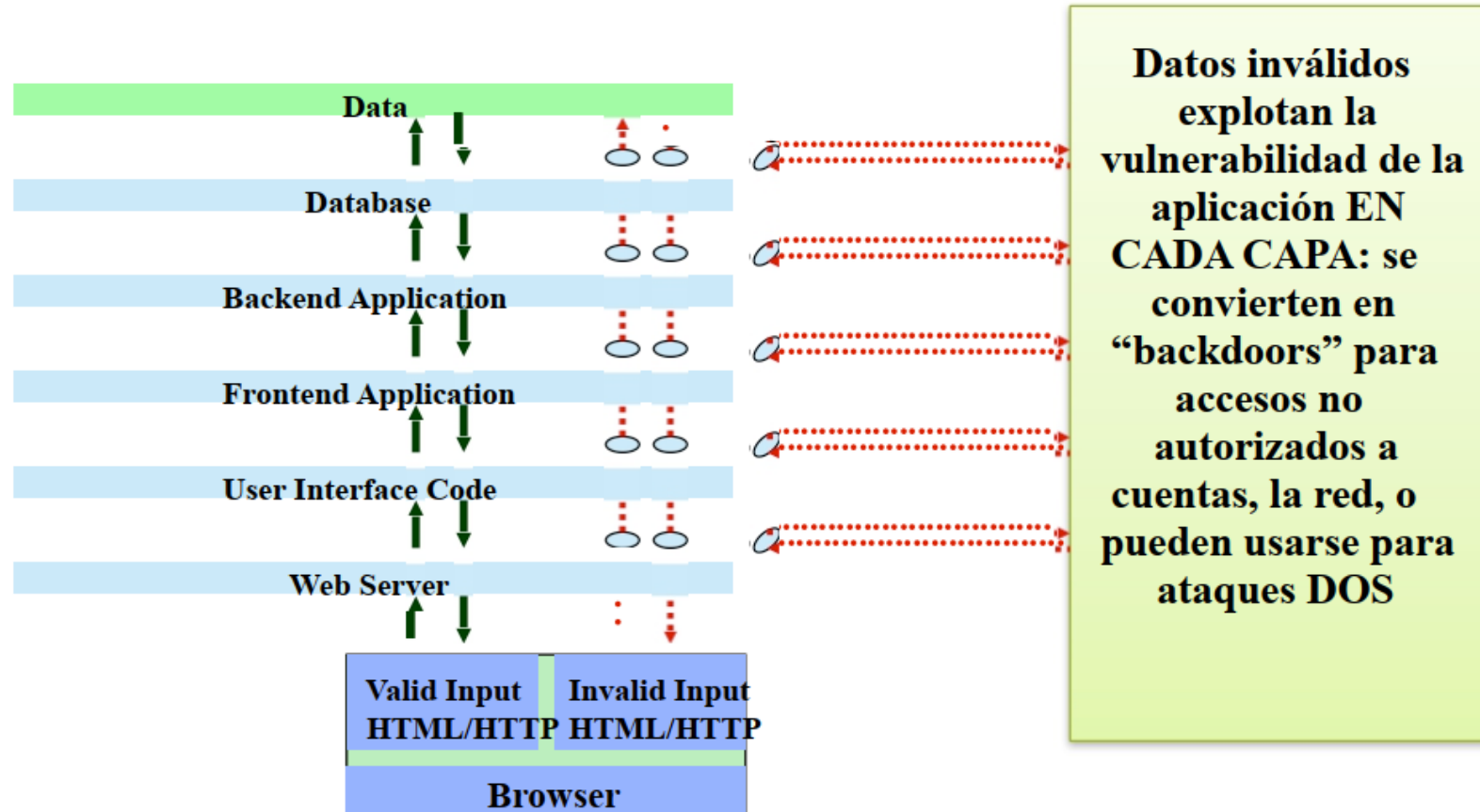


Vulnerabilidades: Web

"If builders built buildings the way programmers wrote programs, then the first woodpecker that came along would destroy civilization."

Weinberg's Second Law

Vulnerabilidades: Web

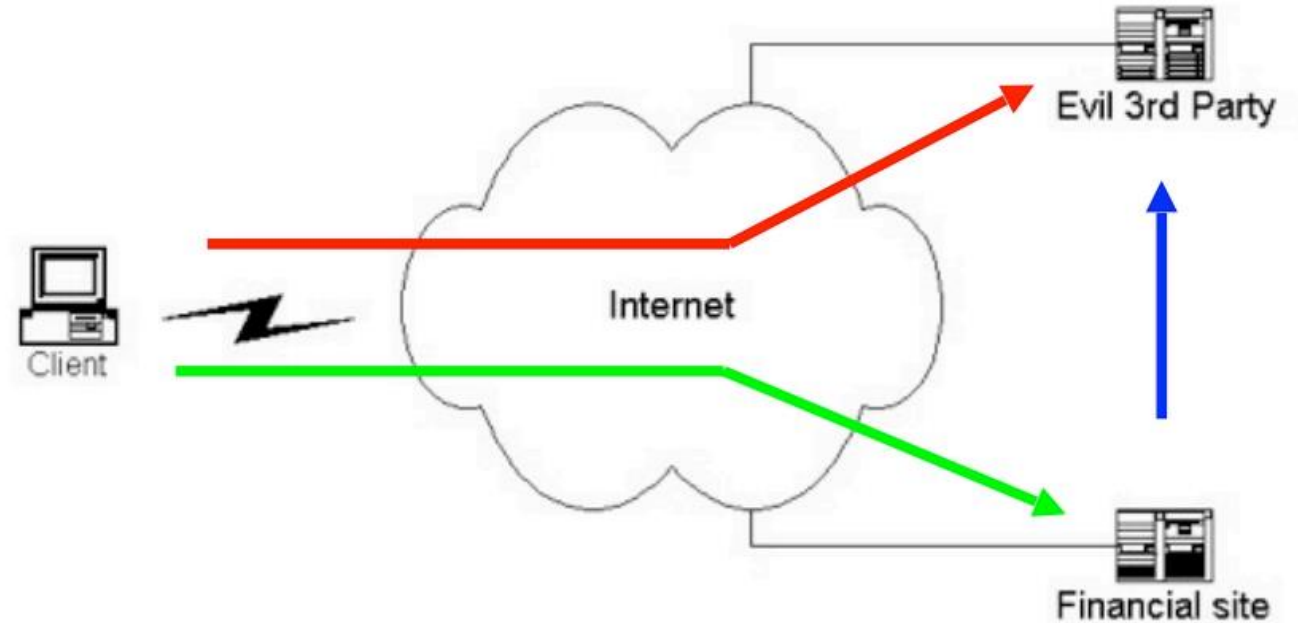


Vulnerabilidades Web: Manejo

Plataforma	Administración	Aplicación
• Vulnerabilidades conocidas (shells)	• Chequeo de Extensiones • Chequeo de Archivos comunes • Chequeo de Extensiones de Datos • Chequeo de Backup • Control de Directorios • Truncar Paths • Vigilar Archivos Ocultos • Web • Browsing forzado	• Mapeo de amenazas • Manejo de cookies • Manipulación de parámetros • Reverse Directory • Fuerza bruta • Cookie Poisoning/Theft • Buffer overflow • SQL Injection • Cross-site scripting

Web: XSS Cross site scripting

- Inyección de scripts maliciosos en sitios web confiables
- Proceso
 - URL tiene un parámetro con un script malicioso
 - Cuando el usuario se conecta, descarga el script malicioso que escucha passwords y usernames, y los envía a otro lugar (usando POST u otros)



Defensa en arquitectura

- Especifica los mecanismos de seguridad a ser parte de la arquitectura de software
- Subsistemas
 - Servidores web, servidores de aplicación, DBMS, directorios, aplicaciones web, y aplicaciones legadas
- Conectores entre subsistemas
 - Llamadas a funciones remotas o locales, protocolos (SSL, HTTPS, LDAP)
- Mecanismos específicos
 - Autenticación y autorización, encriptación, auditoria, manejo de bitácoras, monitoreo, detección de intrusos, registros, backup, recuperación ante fallas



Patrones de seguridad

- Soluciones comunes a problemas recurrentes en seguridad
- Similares a los patrones en arquitectura
 - Reusables
 - Probados
 - Genéricos
 - Resultados de experiencia
- Listado más completo en Security "Security Patterns: Integrating Security and Systems Engineering"

Same origin policy

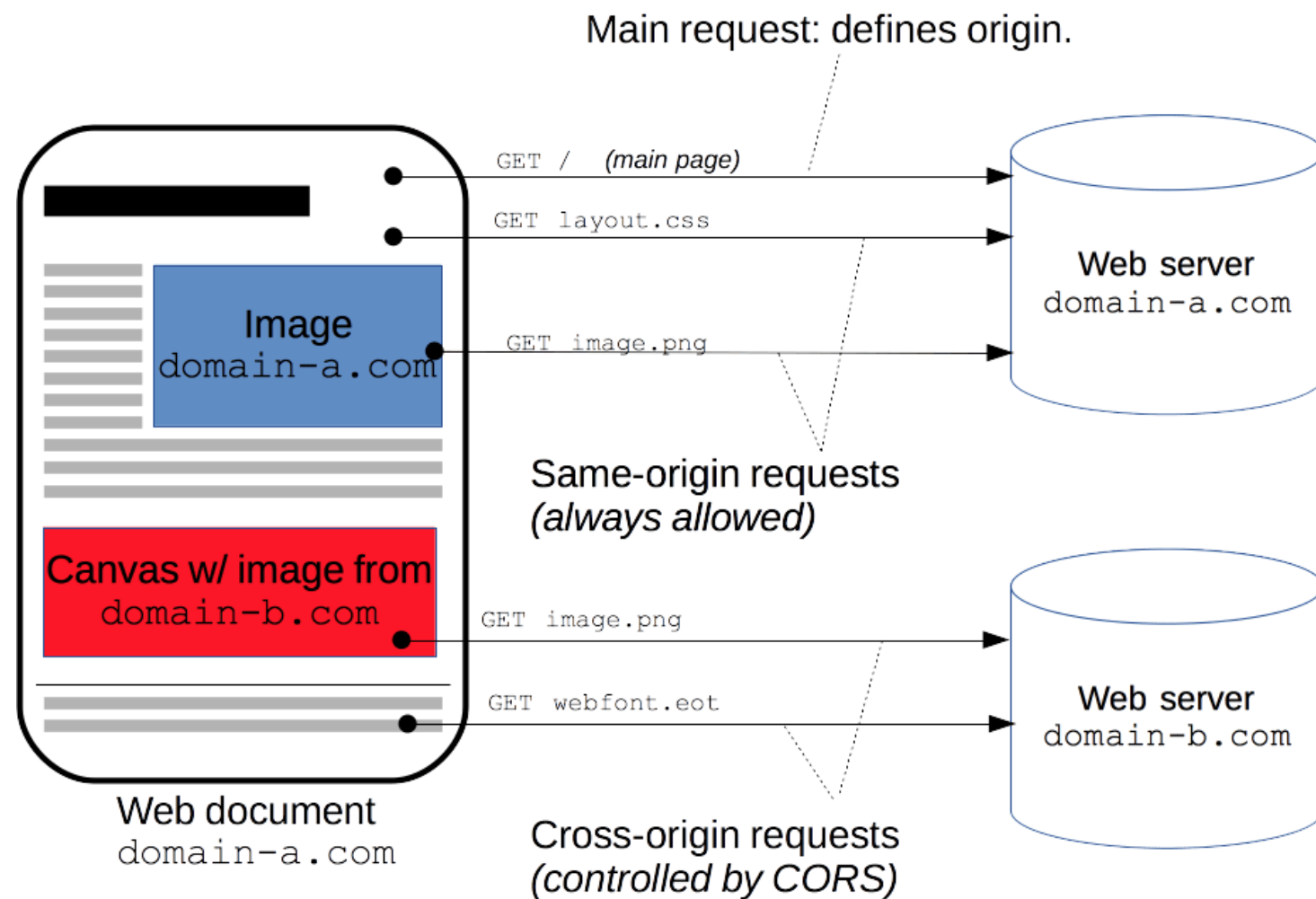
- Política de seguridad para lenguajes que se ejecutan en el lado del browser (ej. Javascript)
- Los scripts que corren en páginas servidas por un sitio acceden únicamente a los objetos, métodos y propiedades (DOM, cookies) de las páginas originadas en el mismo sitio, pero previenen el acceso a los métodos y propiedades de sitios diferentes
- ¿Qué es el “origen”?

Ejemplos de origins

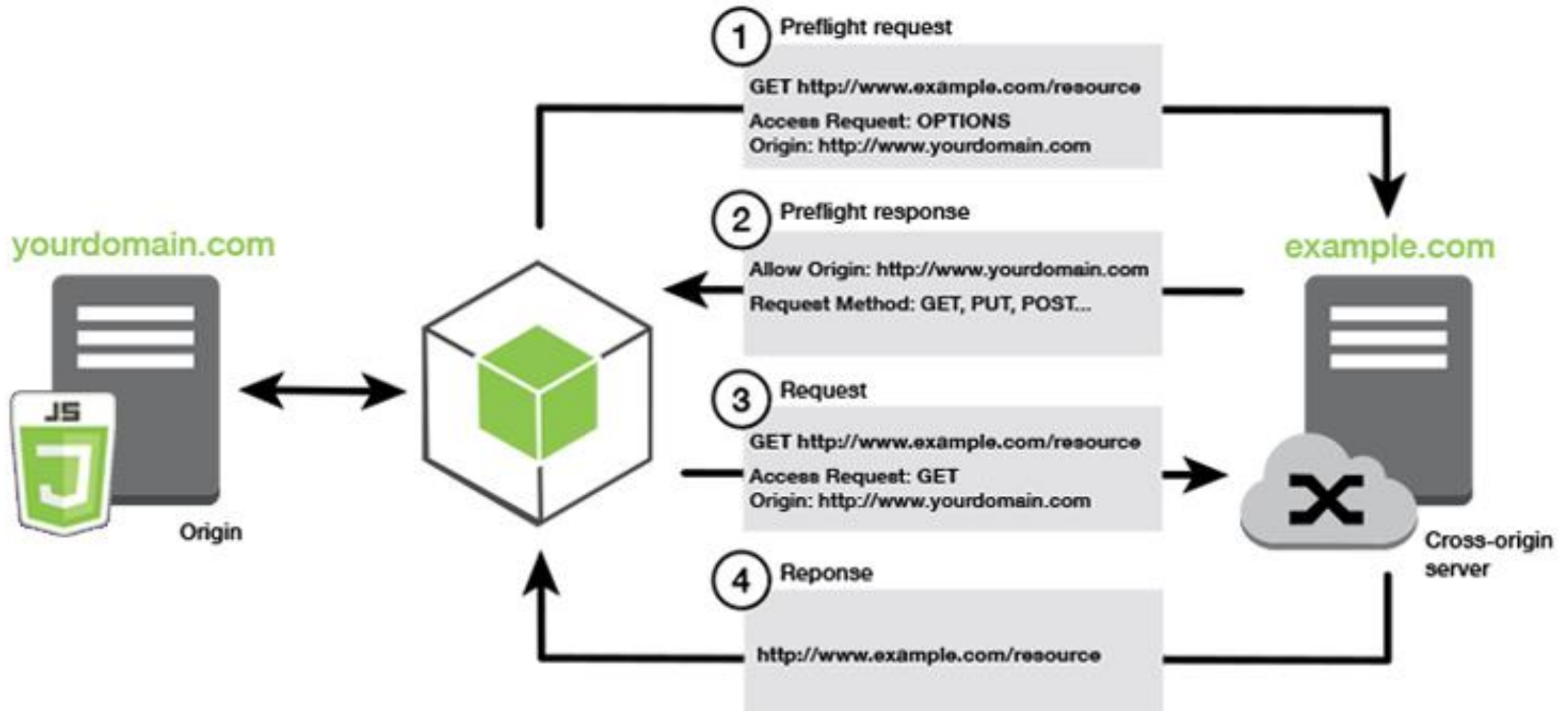
Compared URL	Outcome	Reason
http://www.example.com /dir/page2.html	Success	Same protocol, host and port
http://www.example.com /dir2/other.html	Success	Same protocol, host and port
http://username:password@www.example.com /dir2/other.html	Success	Same protocol, host and port
http://www.example.com: 81 /dir/other.html	Failure	Same protocol and host but different port
https ://www.example.com/dir/other.html	Failure	Different protocol
http:// en.example.com /dir/other.html	Failure	Different host
http:// example.com /dir/other.html	Failure	Different host (exact match required)
http:// v2.www.example.com /dir/other.html	Failure	Different host (exact match required)
http://www.example.com: 80 /dir/other.html	Depends	Port explicit. Depends on implementation in browser.

Cross origin requests

- Afecta a XMLHttpRequest (ECMA script HTTP API)
- Falta de proteccion puede permitir XSS
 - Scripts en contenido
 - Redirecciones



Cross origin requests sharing



CORS

- HTTP requests a recursos de dominios diferentes al dominio del recurso (e.g. javascript) que hace la llamada
- W3C
- Afecta a varios recursos
 - XMLHttpRequest
 - Web fonts
 - WebGL
 - Imágenes

▼ General

Request URL: http://example.com /cms/wp-content/uploads/201

Request Method: OPTIONS

Status Code: ● 200 OK

Remote Address: 127.0.0.1:60545

Referrer Policy: no-referrer-when-downgrade

▼ Response Headers

[view source](#)

Access-Control-Allow-Credentials: true

Access-Control-Allow-Headers: DNT,X-CustomHeader,Keep-Alive,Us
Content-Type,Content-Range,Range

Access-Control-Allow-Methods: GET, PUT, POST, DELETE, OPTIONS

Access-Control-Allow-Origin: http://example-x.com

Allow: GET,HEAD,POST,OPTIONS

Cache-Control: max-age=0

Content-Length: 0

Content-Type: application/json; charset=utf-8

Date: Mon, 09 Oct 2017 12:42:09 GMT

Expires: Mon, 09 Oct 2017 12:42:09 GMT

Proxy-Connection: Keep-alive

Server: nginx

X-Accel-Version: 0.01

X-Powered-By: PleskLin

X-UA-Compatible: IE=edge,chrome=1



Authentication

- Capacidad de probar la identidad de un usuario, dispositivo o sistema
- Pueden usarse uno o más factores (MFA)
- Objetivos de autenticación
 - Probar ID (Obtener un ID Token)
 - Probar pertenencia a un grupo

Factor	Ejemplo
Sabes	Password PIN API key
Tienes	Smartphone Token Key Generador
Eres	Biometría

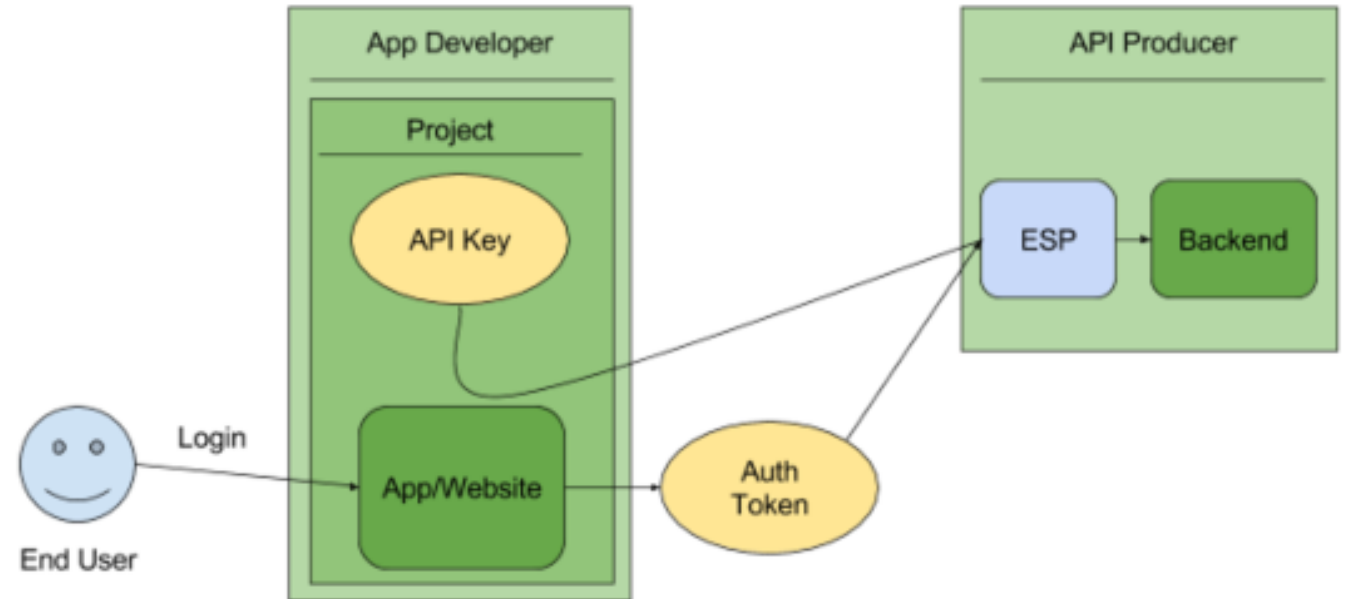


Seguridad III

- IIC2173 - Arquitectura de sistemas de software
- Departamento de Ciencia de la Computación
- Escuela de Ingeniería – PUC
- Nicolás Acosta – Gerardo Crot

Authentication en la web

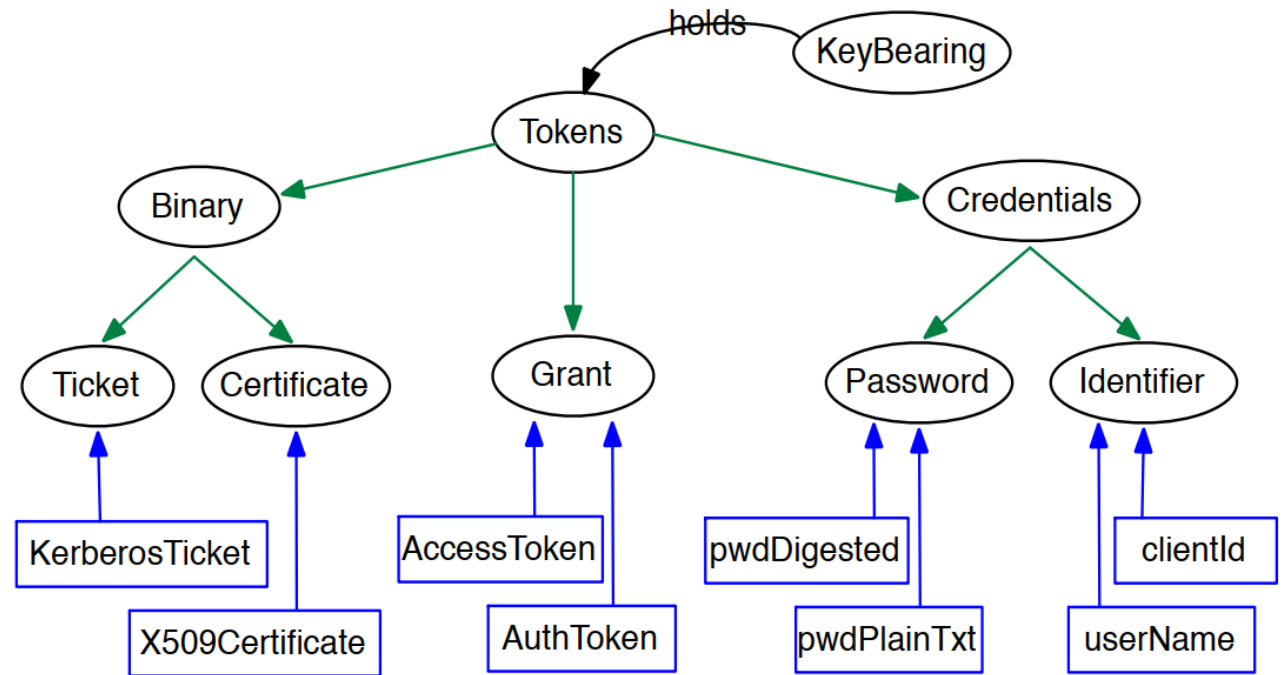
- API Key
 - Credenciales: developer key, developer token, token Id, userId, user key
- Username / password
- Error clásico
 - Uso de GET en credenciales
 - `http://happenr.com/webservices/getEvents.php?username=xxx&password=xxx&town=London`

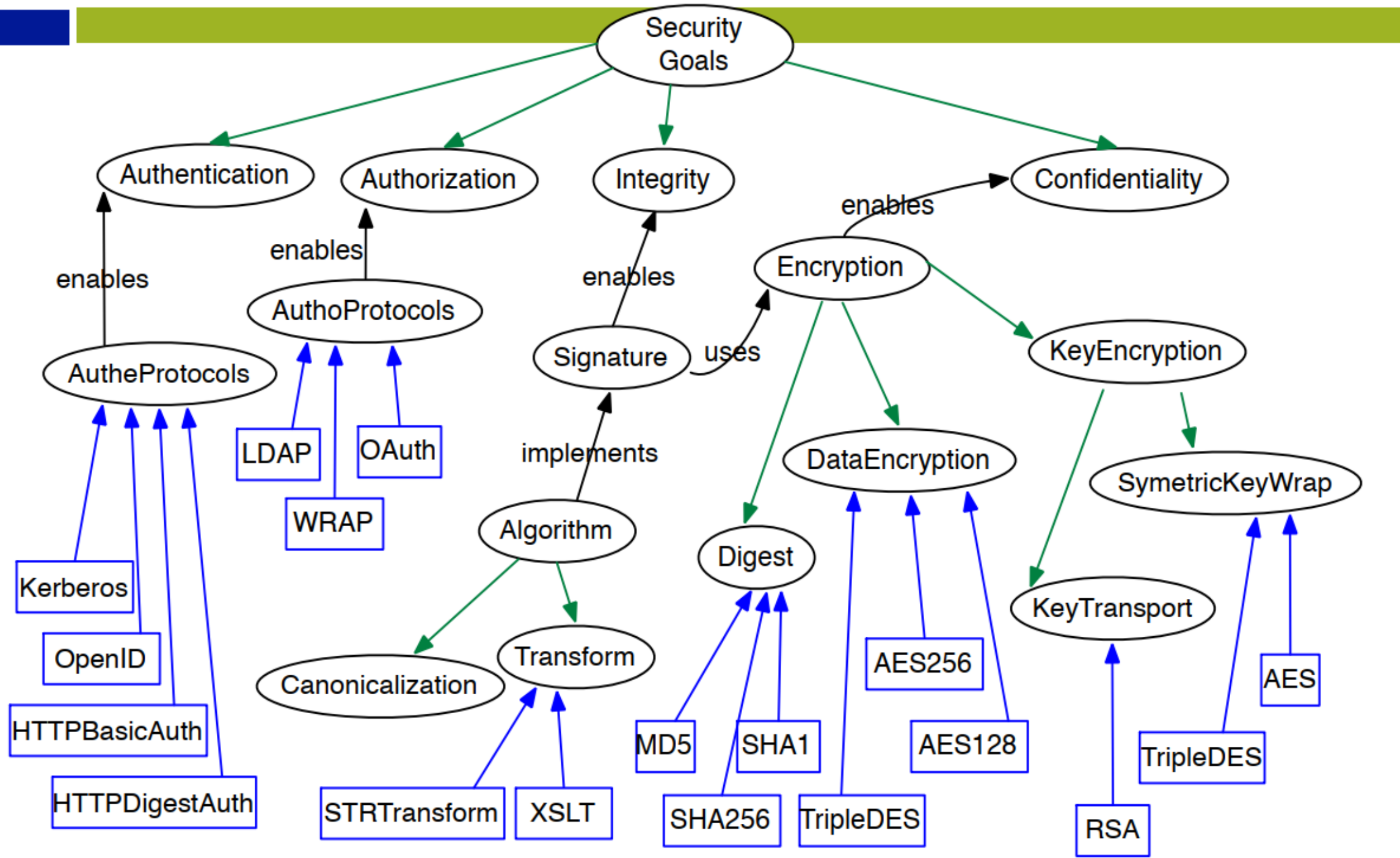


HTTP Basic Authentication



Metas de seguridad: Identidad





Authorization

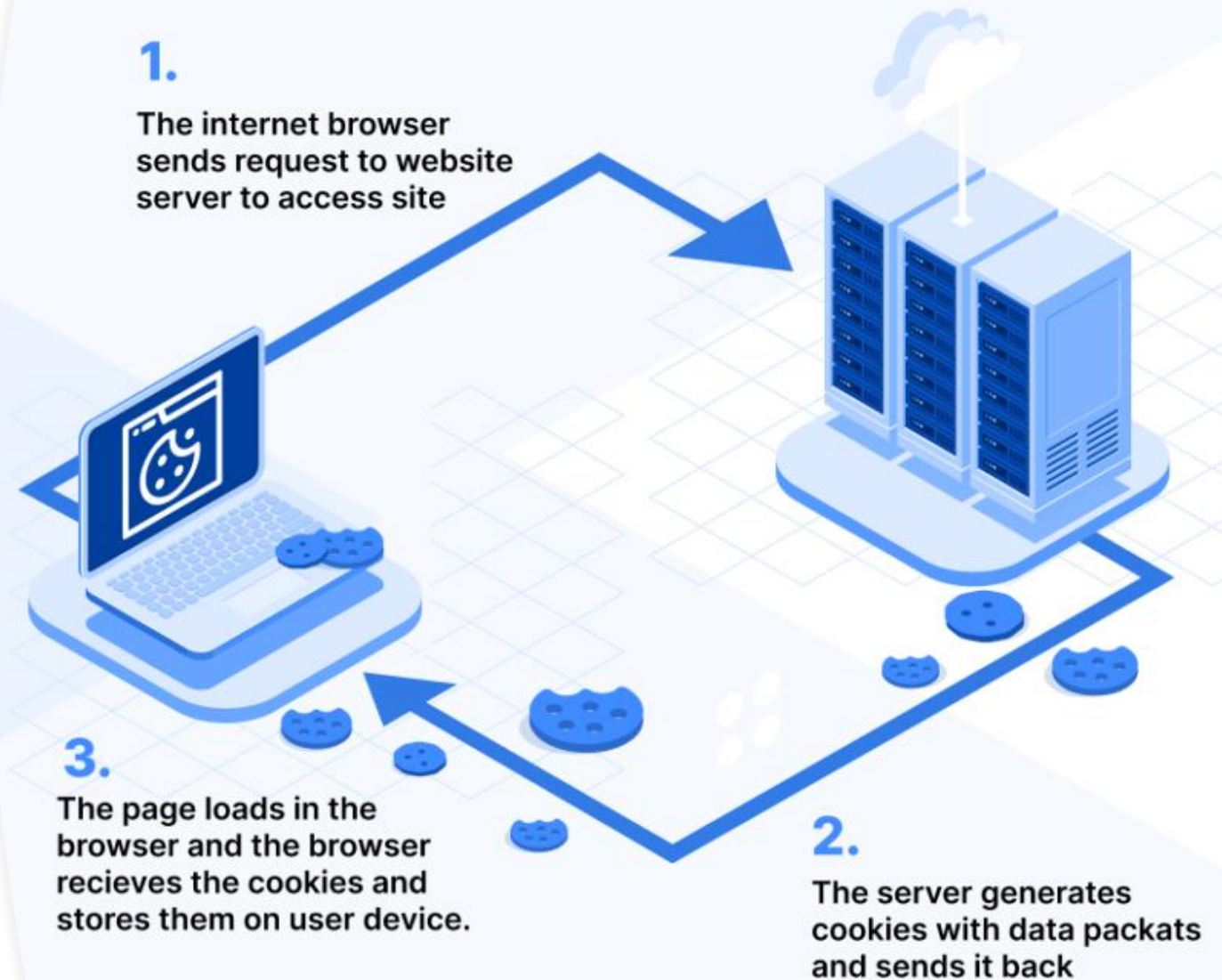
- Determinar si un actor autenticado tiene privilegios para acceder o modificar datos o servicios.
- Requiere tener un sistema firme de autenticación para implementar



Cookies

- Pequeño trozo de información almacenado en un sistema para uso de un navegador web
- Tracking de sesión
 - Auth/Auth
 - Evitar “multilogins”

How cookies work



CSRF sobre cookies



①

A hacker creates a request (in the form of a URL) for their own benefit from a website



②

Hacker embeds that request into a hyperlink and sends it to a visitor who they hope is logged in to the site



③

The website visitor clicks the link, unwittingly sending the request to the site



④

Assuming the request is legitimate, the website fulfills the request, sending data, funds, or access to the hacker

Access control methods

- ACL: Access control list
 - Define los permisos (operaciones) asignados a un objeto según el usuario
 - Ejemplos
 - S3, Filesystem: Ext3, Richacl
 - Trafico de firewalls, Reglas para manejo de puertos
 - Programas: Modelo de seguridad basado en ACLs
- Role based Access control
 - AWS IAM
- Claim based Access control

Resource Permissions (optional) [Info](#)

Add a new resource policy or edit resource policy to access secrets across AWS accounts securely

Cancel

Save

```
1 {  
2   "Version": "2012-10-17",  
3   "Statement": [  
4     {  
5       "Effect": "Allow",  
6       "Principal": {  
7         "AWS": "arn:aws:iam::PRODUCTION:role/PRODUCTION_ROLE"  
8       },  
9       "Action": "secretsmanager:GetSecretValue",  
10      "Resource": "*",  
11      "Condition": {  
12        "ForAnyValue:StringEquals": {  
13          "secretsmanager:VersionStage": "AWSCURRENT"  
14        }  
15      }  
16    }  
17  ]  
18 }
```

OAuth

- Protocolo de autorización IETF
- Permite autorizar a terceras aplicaciones para que accedan de manera limitada a servicios HTTP, en representación de un usuario final
- Orquesta una interacción de aprobación entre el usuario final y el servicio HTTP

<http://tools.ietf.org/html/draft-ietf-oauth-v2-15>

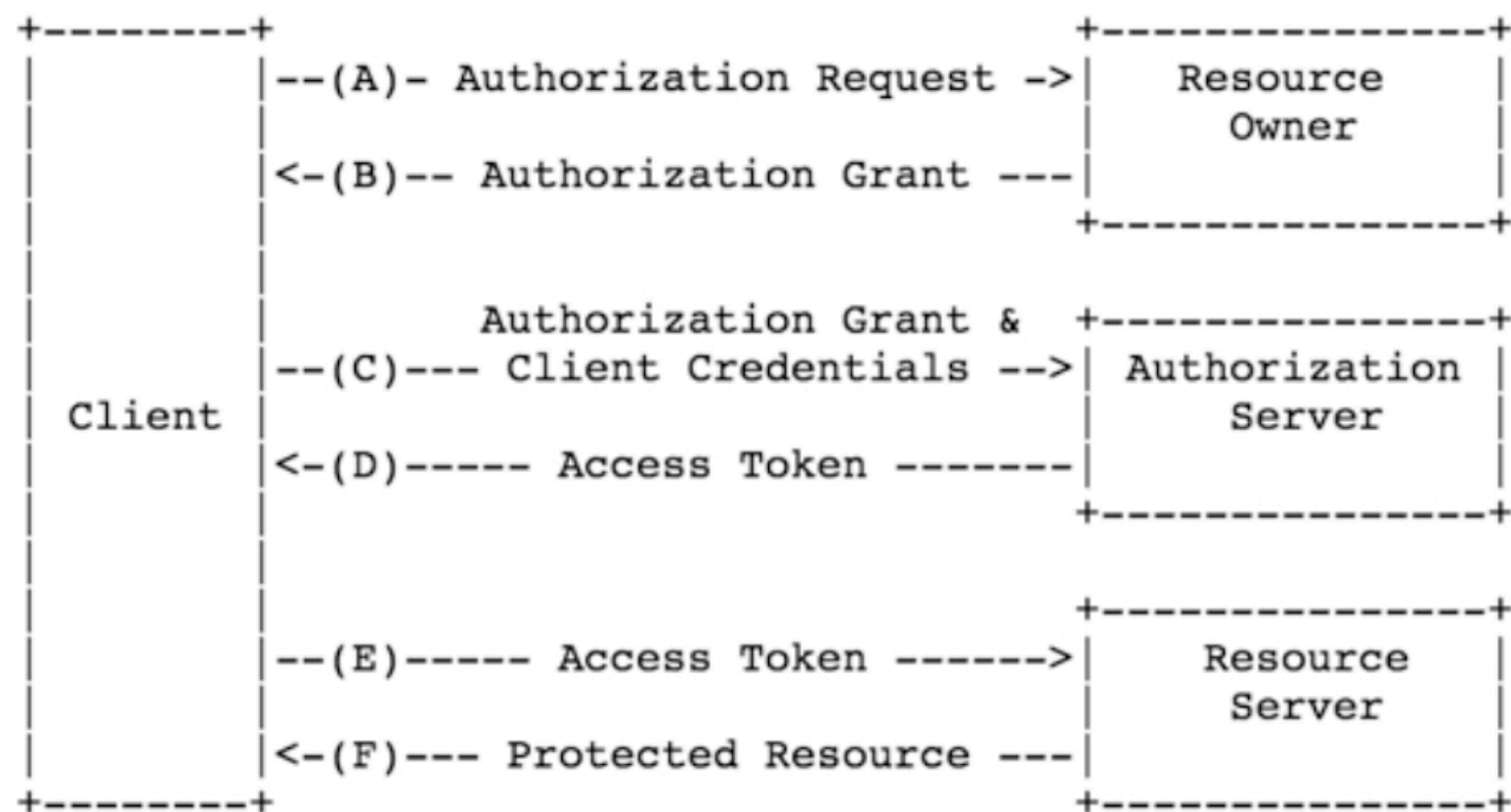


Figure 1: Abstract Protocol Flow

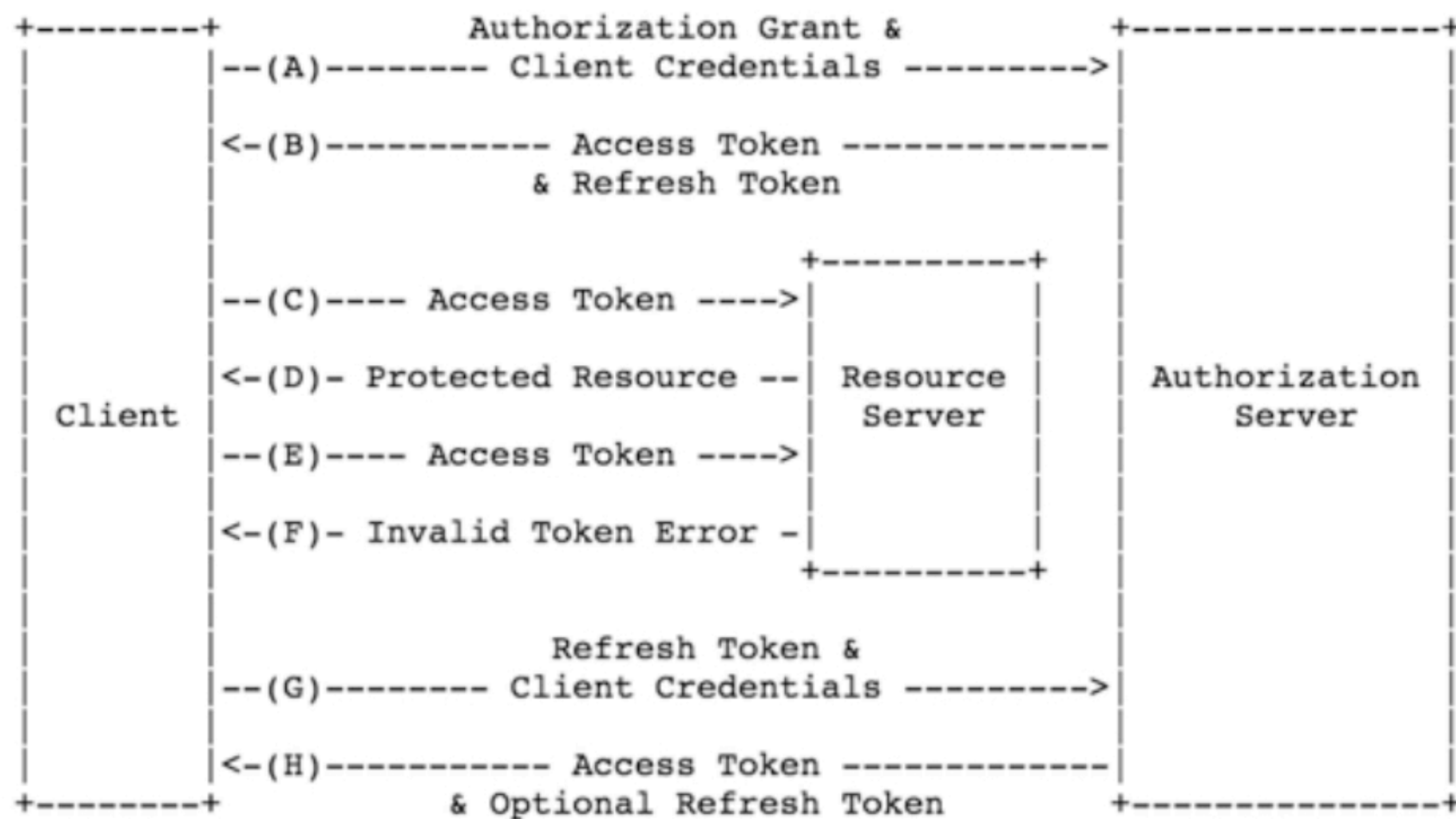
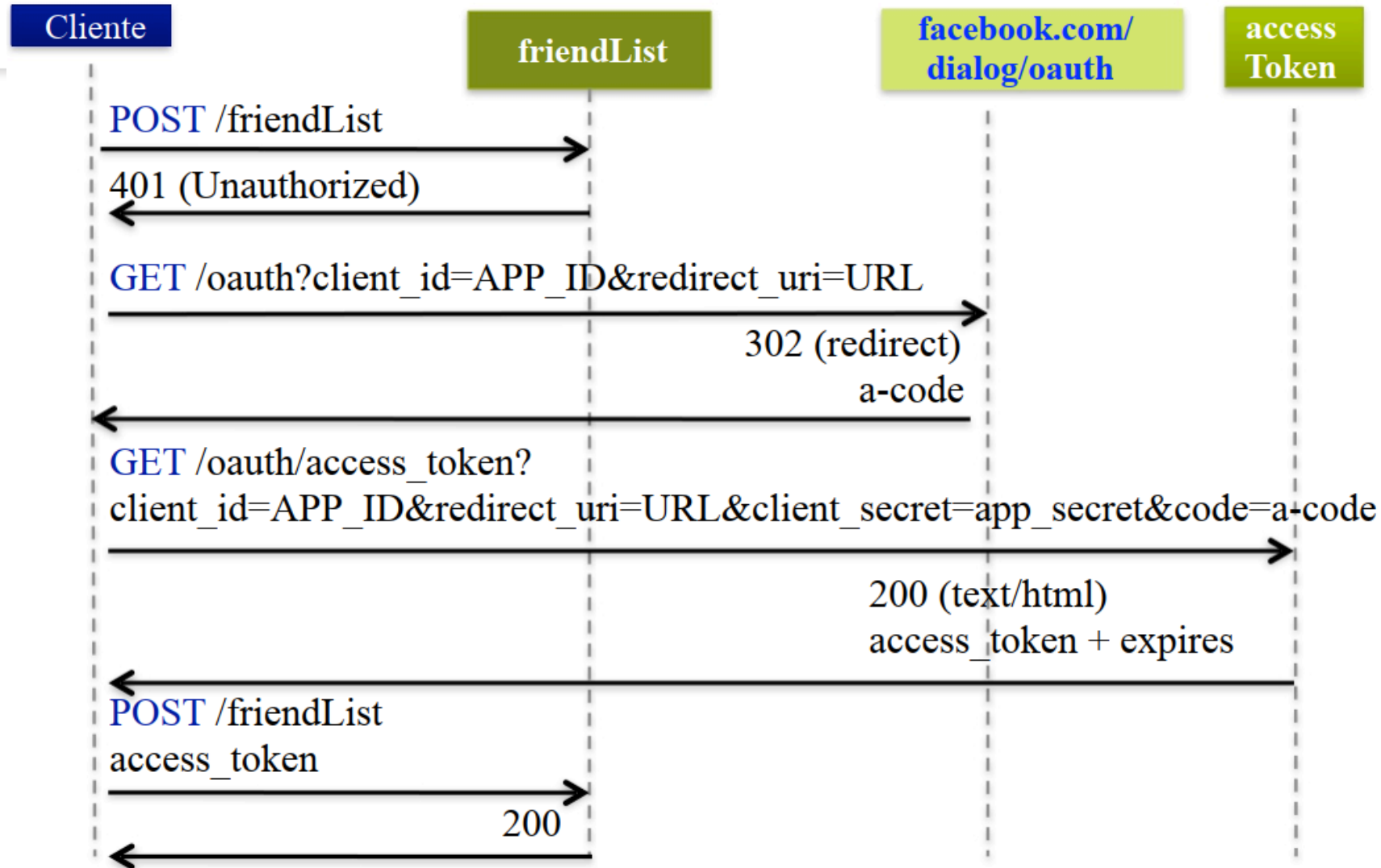


Figure 2: Refreshing an Expired Access Token

OAuth: Facebook



JWT

- JSON Web Token (JWT) se basa en RFC 7519
- Tokens autocontenidos
 - Vienen firmados
 - Traen metadata y payload
- Promueve sistemas stateless
 - A diferencia de otros sistemas

The screenshot shows the JWT.io web application interface. At the top, there's a navigation bar with the JWT logo, a 'Debugger' button, and links for 'Libraries', 'Ask', and 'Get a T-shirt!'. Below the navigation bar, there's a dropdown menu for 'ALGORITHM' set to 'HS256'. The main content area is divided into two columns: 'Encoded' and 'Decoded'. The 'Encoded' column displays a long string of base64-encoded characters. The 'Decoded' column shows the decoded token structure, including the 'HEADER' and 'PAYLOAD' sections. The 'HEADER' section contains a JSON object with 'alg' set to 'HS256' and 'typ' set to 'JWT'. The 'PAYLOAD' section contains a JSON object with 'sub' set to '1234567890', 'name' set to 'John Doe', and 'admin' set to 'true'. Below the 'PAYLOAD' section, there's a 'VERIFY SIGNATURE' section with a text input field containing 'secret' and a checkbox labeled 'secret base64 encoded'. At the bottom of the interface, there's a blue banner with a checkmark icon and the text 'Signature Verified'.

JSON Web Tokens - jwt.io

JWT

Debugger Libraries Ask Get a T-shirt!

ALGORITHM HS256

Encoded

```
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxMjM0NTY3ODkwIiwibmFtZSI6IkpvaG4gRG9lIiwiaWF0IjoiYWRtaW4iOnRydWV9.TJVA95OrM7E2cBab30RMHrHDcEfxjoYZgeFONFh7HgQ
```

Decoded

HEADER:

```
{  "alg": "HS256",  "typ": "JWT"}
```

PAYLOAD:

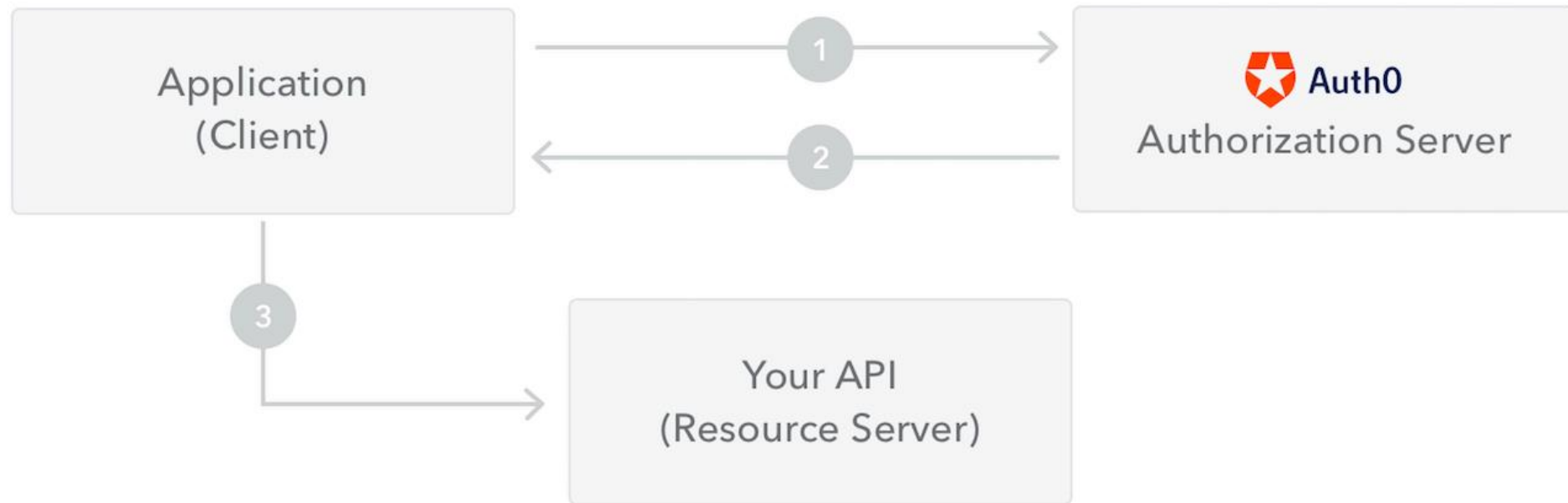
```
{  "sub": "1234567890",  "name": "John Doe",  "admin": true}
```

VERIFY SIGNATURE

```
HMACSHA256(  base64UrlEncode(header) + "." +  base64UrlEncode(payload),  secret  ) ☐ secret base64 encoded
```

Signature Verified

JWT



¿No siempre JWT?

- Deben ser asegurados
 - Las cookies ya las manejan los browsers
- Problema de la repudiación
- Muchos devs hacen una implementación stateful
- Los tokens son demasiado “transparentes”
 - Pueden reflejar info importante

To be clear: This article does *not* argue that you should *never* use JWT - just that it isn't suitable as a session mechanism, and that it is **dangerous** to use it like that. Valid usecases *do* exist for them, in other areas. At the end of this article, I'll briefly go into those other usecases.

Source: “Stop using JWT for sessions” (see reference below for links).

“JSON Web Tokens can be used to validate user locally without the need for database but then you put yourself at risk for massive security issues..”

Source: “Why JWTs Are Bad for Authentication”—[Randall Degges](#), Head of Developer Advocacy, Okta.

Adopting them comes with drawbacks. You either forego revocation, or you need to have infrastructure in place that is way more complex than simply adopting a session store and opaque tokens.

Source: “JWT should not be default for your sessions” (see reference below for links).

I don't care if you want to use stateless client tokens. They're fine. You should understand the operational limitations (they may keep you up late on a Friday scrambling to deploy a token blacklist), but, we're all adults here, and you can make your own decisions about that.

The issue with JWT in particular is that it doesn't bring anything to the table, but comes with a whole lot of terrifying complexity. Worse, you as a developer won't see that complexity: JWT looks like a simple token with a magic cryptographically-protected bag-of-attributes interface. The problems are all behind the scenes.

HMACSHA256(

SAML

Encoded

PASTE A TOKEN HERE

Decoded

EDIT THE PAYLOAD AND SECRET ONLY HS256 SUPPORTED

HEADER: ALGORITHM & TOKEN TYPE

```
{
  "alg": "HS256",
  "typ": "JWT"
}
```

PAYLOAD: DATA

```
{
  "sub": "1234567890",
  "name": "John Doe",
  "admin": true
}
```

VERIFY SIGNATURE

```
HMACSHA256(
    base64UrlEncode(header) + "." +
    base64UrlEncode(payload),
    secret
) secret base64 encoded
```

VS

SAB

Debugger

SAMI ENCODED

PASTE A TOKEN HERE

SAMI DECODED

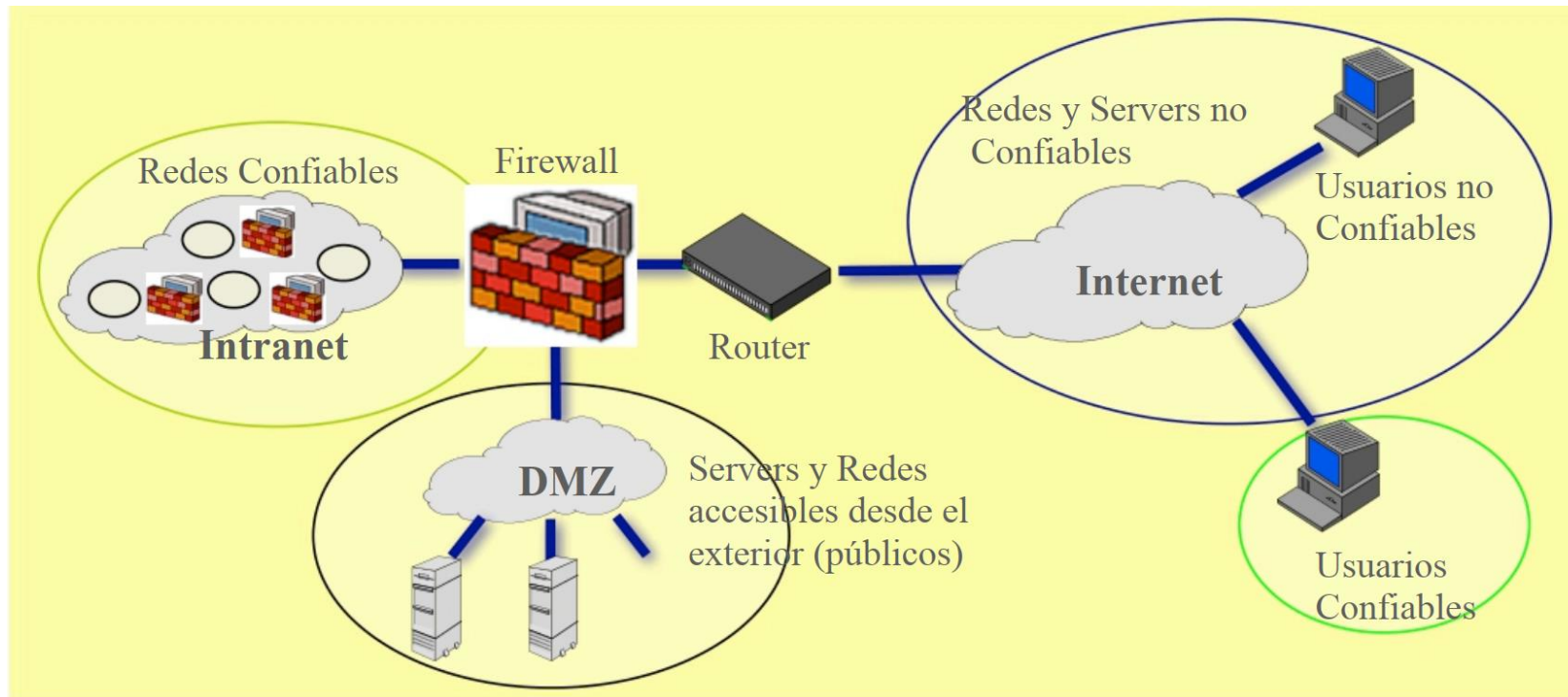
 Drafts (not editable)

[illegible][illegible]

SAML INFO

Firewalls

- Provee conectividad segura entre redes
- Permite aplicar una política de seguridad

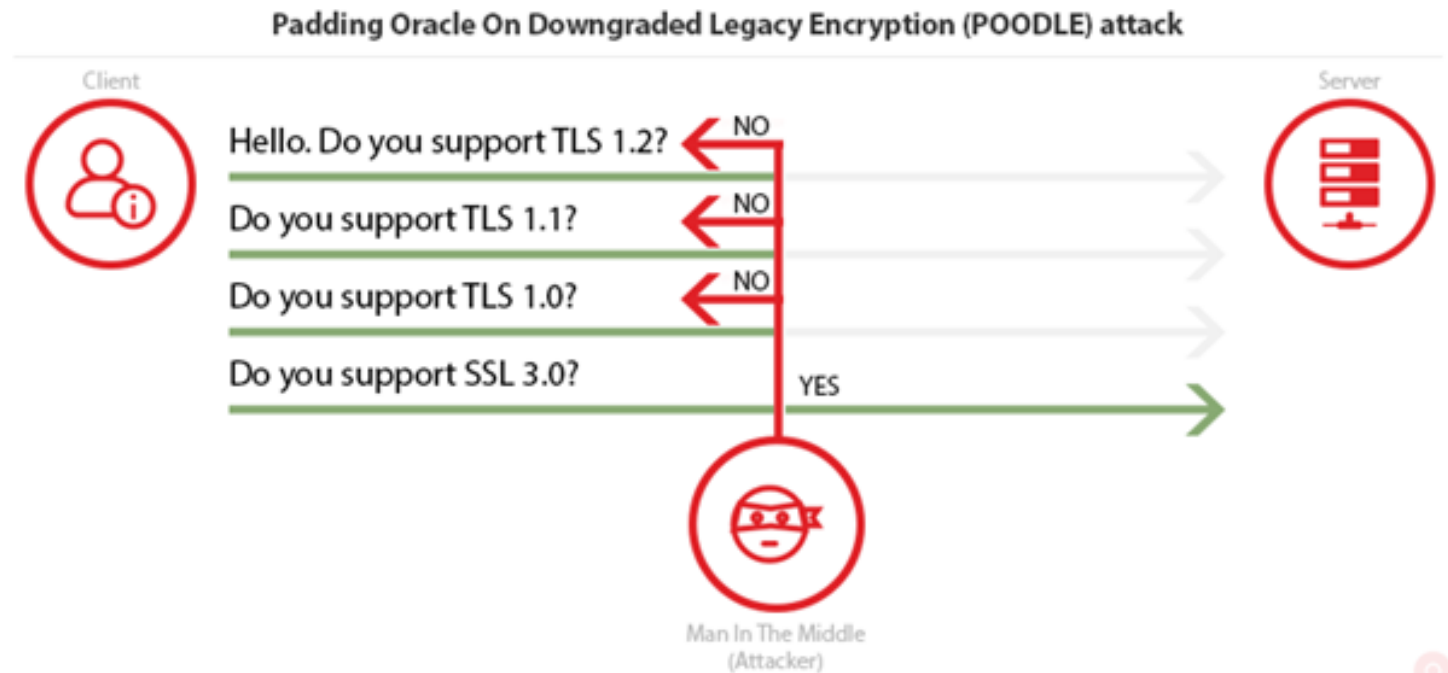


Propiedades de un firewall

- Registra tráfico entrante y saliente:
 - Direcciones IP, puertos y usuarios
- Filtro de paquetes: Bloquea paquetes inválidos (IPs), puede ser router, bridge, host
- Application Proxy: Programa (encriptación)
- Separar servicios internos (gateways) de externos (DNS, webservers, etc.):
 - DMZ (De-Militarized Zone)
 - Area entre 2 filtradores (interno/externo) de paquetes

HTTPS

- Protección del protocolo de transmisión
- Sujeto a múltiples estándares (cipher suites)
 - Algunos de ellos obsoletos
- Ojo con degradación de suite!



Principios adicionales

- Protect the Brand **Your Customers Trust**
- **Know Your Business** and Support it with Secure Solutions
- Understand the Technology of the Software
- **Ensure Compliance** to Governance, Regulations, and
- Privacy
- Know the **Basic Tenets of Software Security**
 - Confidencialidad, Integridad, Disponibilidad, Autenticación, Autorización, “Responsabilidad”, Configuración de uso, Sesiones y Excepciones

Principios adicionales

- Ensure the **Protection of Sensitive Information**
- Design Software with Secure Features
- Develop Software with Secure Features
- Deploy Software with Secure Features
- **Educate Yourself** and Others on How to Build Secure Software



Grandes casos

- Ashley madison
- Mirai
- Yahoo (2013-2014, 2017)
- Alibaba (2022)
- Filtraciones gubernamentales
 - Snowden
 - Mason
 - WikiLeaks
- Equifax (2017)
- Solarwinds (2020)

Ashley Madison

- “Sitio de citas online” para personas casadas y/o comprometidas (https://en.wikipedia.org/wiki/Ashley_Madison)
 - Se paga para iniciar una conversación (con expiración)
 - Se paga para “borrar” la cuenta
- “Breach”
 - Bots simulando ser mujeres
 - La seguridad de los datos era insuficiente
 - Los datos no se estaban borrando de verdad

Casualties en Ashley Madison

- Accesos “no autorizados”
- 20-07-2015: Robo masivo de datos
- 20-08-2015: Robo masivo de datos y código fuente
 - 10GB+ de datos comprimidos
 - 33 millones de cuentas nombres, apellidos, datos personales, passwords encriptados
 - ~11 millones de contraseñas descifradas (pass más frecuente: 123456)
 - Información privada (~preferencias)
- Datos parciales de tarjetas de crédito, dirección y sus respectivas transacciones (con GPS)



Ashley Madison

- Técnicas probablemente utilizadas:
 - Phishing
 - SQL injection
 - credenciales re-utilizadas
- Medidas de seguridad posibles
 - Información de transacciones “tokenizadas”
 - Almacenamiento parcial de información de tarjetas de crédito
 - Passwords encriptados con bcrypt
 - Mails y passwords en tablas separadas (dificulta relacionar la información)

Ashley Madison

- Grandes aprendizajes (errores de Ashley Madison)
 - Espacio de disco es barato, pero no así los datos
 - En este caso son muy privados. Se debe esconder (oscurecer y encriptar) todo lo que se pueda.
 - Separar las máquinas que tienen la información (pueden tener acceso a parte de los datos)
- Cuando se detecta una falla de seguridad, se debe arreglar de inmediato
 - Y así evitar un segundo acceso no autorizado

Fuentes:

<https://securityintelligence.com/two-important-lessons-from-the-ashley-madison-breach/>

https://en.wikipedia.org/wiki/Ashley_Madison_data_breach

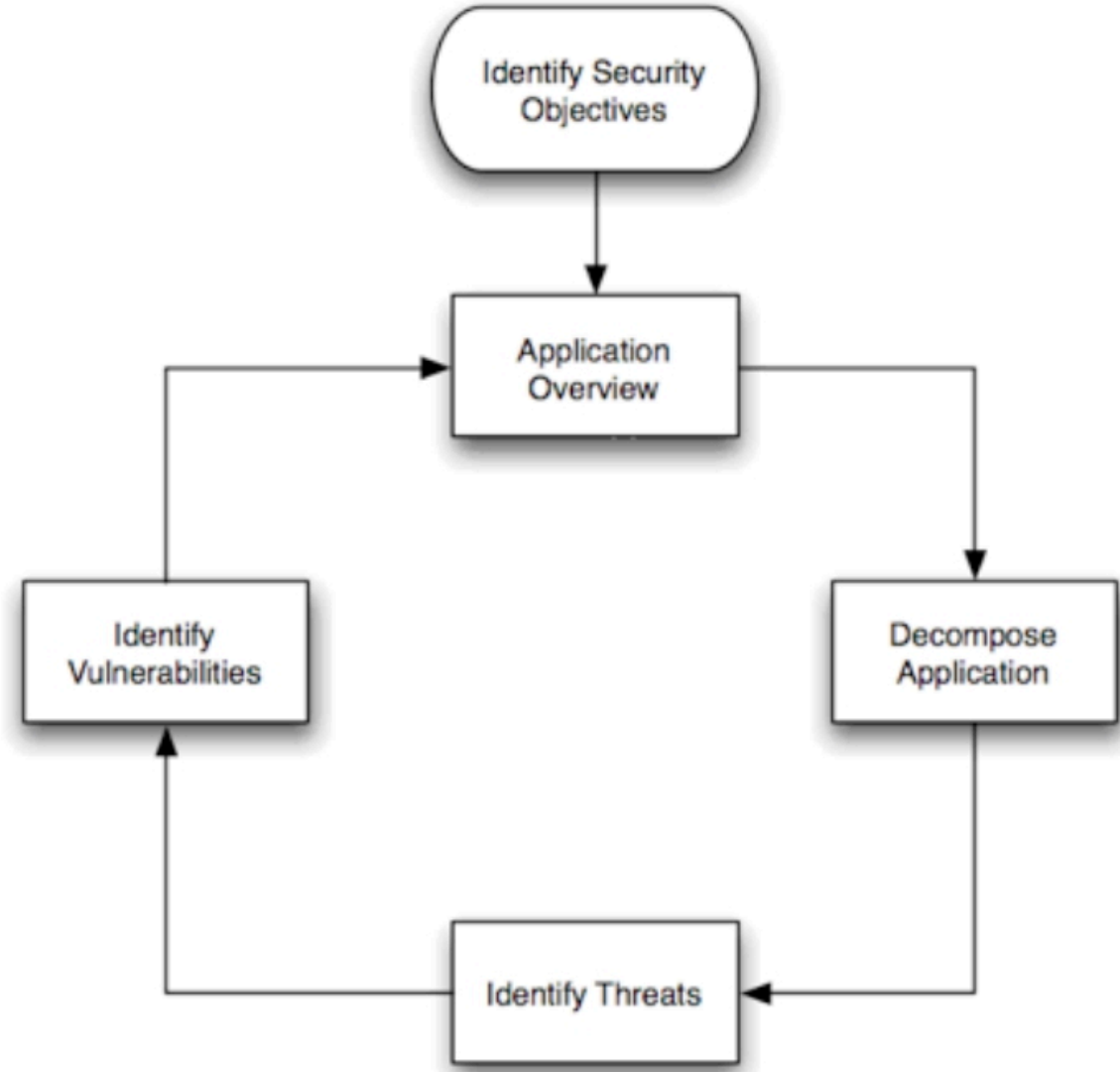
<http://arstechnica.com/security/2015/08/ashley-madison-hack-is-not-only-real-its-worse-than-we-thought/>

<http://blog.erratasec.com/2015/08/notes-on-ashley-madison-dump.html#.V8dOEpmrJE5>

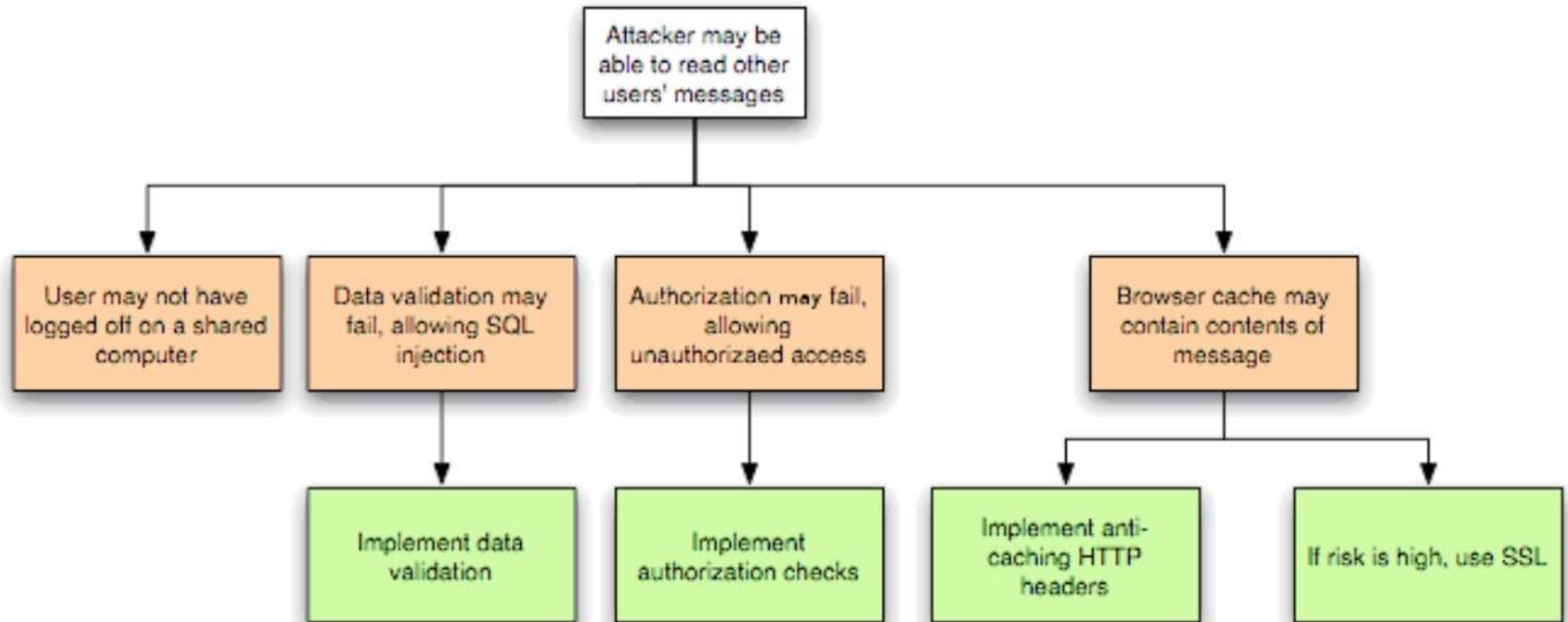
<http://www.theverge.com/2015/8/20/9185469/ashley-madison-leak-contents-email-archive-biderman>

Threat Risk Modeling

- https://www.owasp.org/index.php/Threat_Risk_Modeling
- “Threat modeling works to **identify, communicate, and understand threats and mitigations** within the context of protecting something of value.”



Threat risk modeling



Auditing y estándares

- Evaluación de sistemas conforme a una serie de criterios conocidos
- Permanentemente *se debe testear compliance*
 - Auditorías internas/externas
 - Personal especializado
 - CISO
 - SecOps
 - Concientización generalizada
 - Pentesting





Microsoft Azure - The most comprehensive compliance coverage in the industry

Defense				
	☒ DoD DISA SRG Level 4 ☒ DoD DISA SRG Level 5	☒ DoD DISA SRG Level 2 ☒ DFARS	☒ Australia IRAP Unclassified ☒ Australia IRAP PROTECTED	☒ Spain ENS High
 Global	☒ ISO 27001:2013 ☒ ISO 27017:2015 ☒ ISO 27018:2014	☒ ISO 22301:2012 ☒ ISO 9001:2015 ☒ ISO 20000-1:2011	☒ SOC 1 Type 2 ☒ SOC 2 Type 2 ☒ SOC 3 ☒ CIS Benchmark	☒ CSA STAR Certification ☒ CSA STAR Attestation ☒ CSA STAR Self-Assessment ☒ WCAG 2.0 (ISO 40500:2012)
 US Government	☒ FedRAMP High ☒ FedRAMP Moderate ☒ EAR	☒ ITAR ☒ DoE 10 CFR Part 810 ☒ NIST SP 800-171	☒ NIST CSF ☒ Section 508 VPATs ☒ FIPS 140-2	☒ CJIS ☒ IRS 1075 ☒ CNSSI 1253
 Industry	☒ PCI DSS Level 1 ☒ GLBA (US) ☒ FFIEC (US) ☒ Shared Assessments (US) ☒ SEC 17a-4 (US) ☒ CFTC 1.31 (US) ☒ FINRA 4511 (US) ☒ SOX (US) ☒ 23 NYCRR 500 (US)	☒ OSFI (Canada) ☒ FCA + PRA (UK) ☒ APRA (Australia) ☒ FINMA (Switzerland) ☒ FSA (Denmark) ☒ RBI + IRDAI (India) ☒ MAS + ABS (Singapore) ☒ NBB + FSMA (Belgium) ☒ AFM + DNB (Netherlands)	☒ AMF + ACPR (France) ☒ KNF (Poland) ☒ European Banking Authority (EBA) ☒ FISC (Japan) ☒ HIPAA BAA (US) ☒ HITRUST Certification ☒ GxP (FDA 21 CFR Part 11) ☒ MARS-E (US)	☒ NHS IG Toolkit (UK) ☒ NEN 7510:2011 (Netherlands) ☒ FERPA (US) ☒ CDSA ☒ MPAA (US) ☒ FACT (UK) ☒ DPP (UK) ☒ HDS (France)
 Regional	☒ Argentina PDPA ☒ Canada Privacy Laws ☒ China GB 18030:2005 ☒ China DJCP (MLPS) Level 3 ☒ China TRUCS / CCCPPF ☒ EU EN 301 549	☒ EU ENISA IAF ☒ EU Model Clauses ☒ EU – US Privacy Shield ☒ GDPR ☒ Germany CS ☒ Germany TISAX	☒ Germany IT-Grundschutz workbook ☒ India MeitY ☒ Japan CS Mark Gold ☒ Japan My Number Act ☒ Korea ISMS ☒ Netherlands BIR 2012	☒ New Zealand Gov CIO Framework ☒ Singapore MTCS Level 3 ☒ Spain DPA ☒ UK Cyber Essentials Plus ☒ UK G-Cloud ☒ UK PASF

Auditing y estándares

- ¿Qué pasa si no seguimos compliance?
- <https://thehackernews.com/2024/10/iris-h-watchdog-imposes-record-310.html>

Watchdog Imposes Record €310 Million Fine on LinkedIn for GDPR Violations

, 2024  Ravie Lakshmanan



The data protection watchdog on Thursday fined LinkedIn €310 million (\$335 million) for violating the privacy of its users by conducting behavioral analyses of personal data for targeted advertising.

The authority examined LinkedIn's processing of personal data for the purposes of behavioral analysis and targeted advertising of users who have created LinkedIn profiles (members)," the Data Protection

(ISC)² CBK Security Domain Alignment

More info @ www.pauljerimy.com/security-certification-roadmap | 356 certs listed | October 2020

